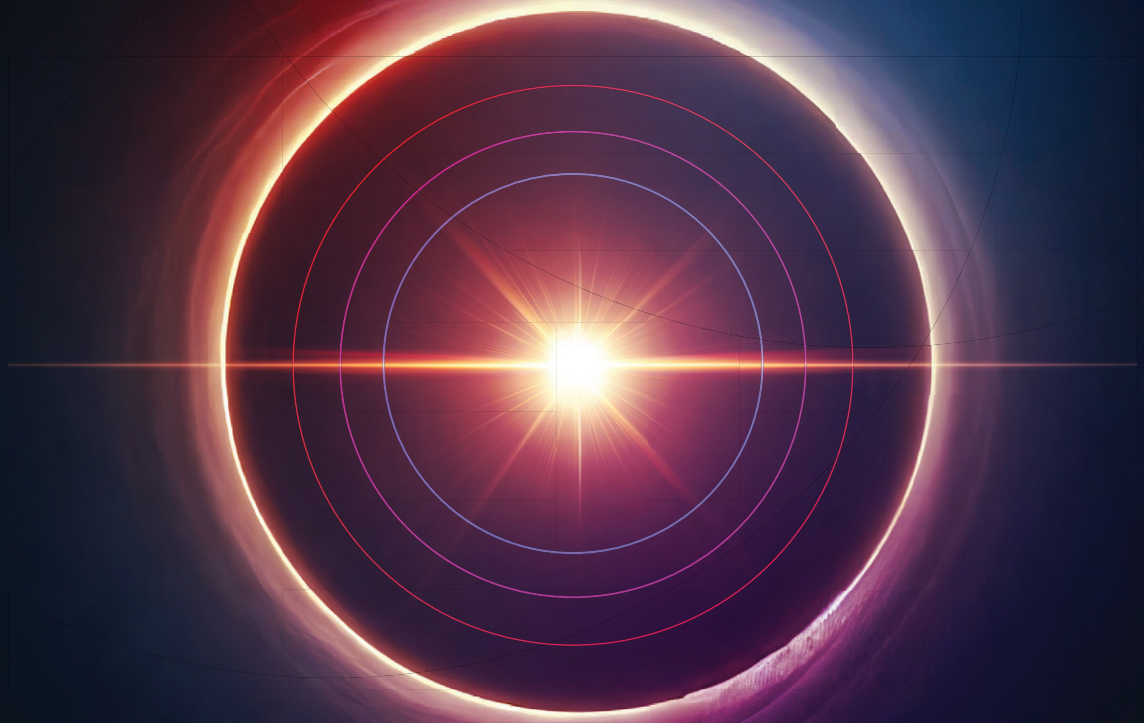
COST OF INSIDER RISKS



GLOBAL REPORT 2025

Independently conducted by

Ponemon INSTITUTE | DTEX

3-5 Introduction

6-9 Executive summary

10-16 Key findings

17 About this study

18-20 Analysis and scope of the insider risk problem

21-38 The cost of insider risk

39-45 Managing the insider risk

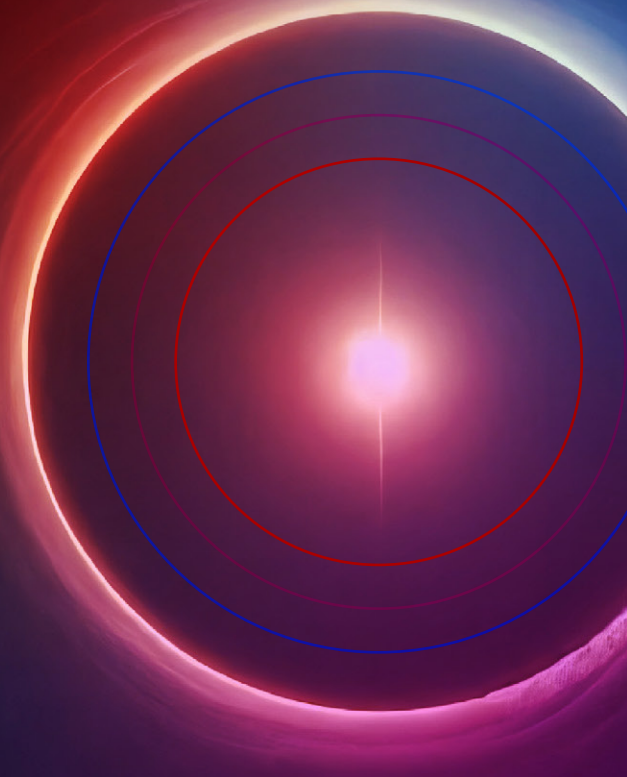
46-48 Demographics

49 Conclusion: From insights to action

50-51 Framework

52-53 Benchmarking

54 Research limitations



About the cover

This year's cover visually reflects the encouraging findings within, signaling light at the end of the tunnel. While insider risk remains a significant challenge, this year's report highlights a clear shift is underway. Maintaining focus and proactive action have never been more important. Great strides take time, but the path forward is clear and promising — positive change is within reach.

Ponemon Institute is pleased to present the findings of the **2025 Cost of Insider Risks Global Report** sponsored by DTEX Systems.

This is the sixth benchmark study conducted to understand the financial consequences that result from insider risks. Expanding on the 2023 edition, this latest report examines how organizations are funding their insider risk management programs and introduces new data evaluating their effectiveness in pre-empting breaches, reducing costs, avoiding regulatory fines, and more.

You can't DETER what you can't DETECT.

Since 2018, participating organizations have more than doubled from 156 to 349. The first study was conducted in 2016 and focused exclusively on companies in North America. Since then, the research has expanded to include organizations in Europe, Middle East, Africa, and Asia-Pacific with a global headcount of 500 to more than 75,000.

> **"Insider risk is a business risk imperative that requires vigilance, trust, and proactive action to get 'left of boom'. The impact of insider risks extends beyond a data breach—it undermines trust and can irreparably harm your reputation."**
>
> - Marshall Heilman, DTEX Systems CEO



STUDY SNAPSHOT

349
Organizations that experienced one or more insider incidents

8,306
IT and IT security practitioners interviewed

7,868
Total number of insider incidents

23
Incidents per company

In the context of this research, insider risks are defined as:

Malicious	Non-malicious	
An insider who seeks to cause harm	**NEGLIGENT** **An insider who causes harm through carelessness or inattentiveness**	**MISTAKEN** **A non-malicious insider who causes harm through a genuine mistake that cannot be attributed to carelessness**
EXAMPLES		
Espionage IP theft Unauthorized disclosure Sabotage Fraud Workplace violence	Ignore warnings	Pressing the incorrect button in a very noisy and stressful environment

Non-malicious
OUTSMARTED **A non-malicious insider who causes harm through being reasonably outmaneuvered by an attack or adversary**
EXAMPLES
Being phished by a new, advanced phishing attack that has not previously been seen in the wild

This graphic is based on **MITRE Corporation's Insider Threat Types**

EXECUTIVE SUMMARY

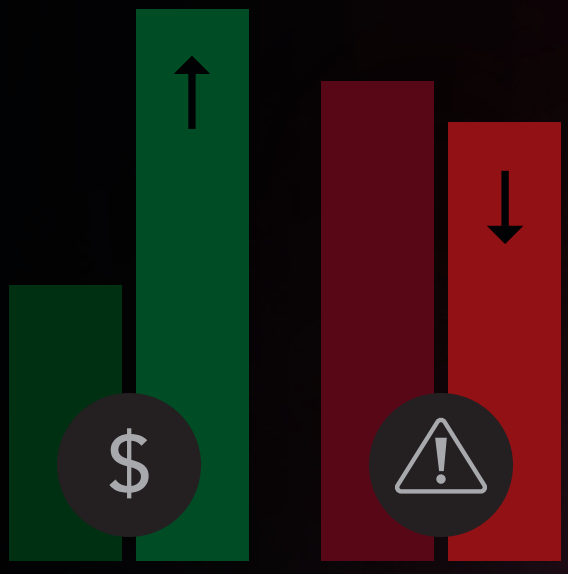
Insider risk management is turning the tide on insider threats.

The total average annual cost of an insider risk has risen to $17.4M USD (up from $16.2M in 2023), but in a historic first, the time to contain insider incidents has declined. The latest data shows that organizations are spending an average of 81 days responding to an insider incident — down from 86.

The overall number of insider incidents has increased to 7,868 — up from 7,343 in 2023 — but the frequency of incidents has declined. Fifty-seven percent of companies experienced between 21 and more than 40 incidents — down from 71% in 2023.

Mirroring findings from the previous report, the biggest activity costs associated with insider risks has occurred after the fact. Containment and incident response increased significantly to $211,021 and $154,819 respectively (up from $179,209 and $113,635).

Insider risk management budgets have more than doubled, and for the first time since the report's inception, the average time to contain insider incidents has declined.



Forty-three percent evaluate insider risk management effectiveness by the length of time to resolve an incident.

This year's report shows growing adoption of insider risk management and positive results from having a program in place.

More than 81% of companies now have or are planning to have an insider risk management program (up from 77% in 2023) and insider risk management budgets have more than doubled to reach 16.5% of their overall IT security budget.

Organizations with insider risk management programs reported significant benefits, with 63% saving time responding to a breach, 61% protecting their company's reputation, and 59% reducing financial losses from a breach.

Artificial intelligence (AI) is also paying off, with over half (54%) of organizations now using AI to detect and prevent insider risks. Of those, 70% ranked the ability to reduce investigation times as one of the top three benefits of AI in insider risk management.

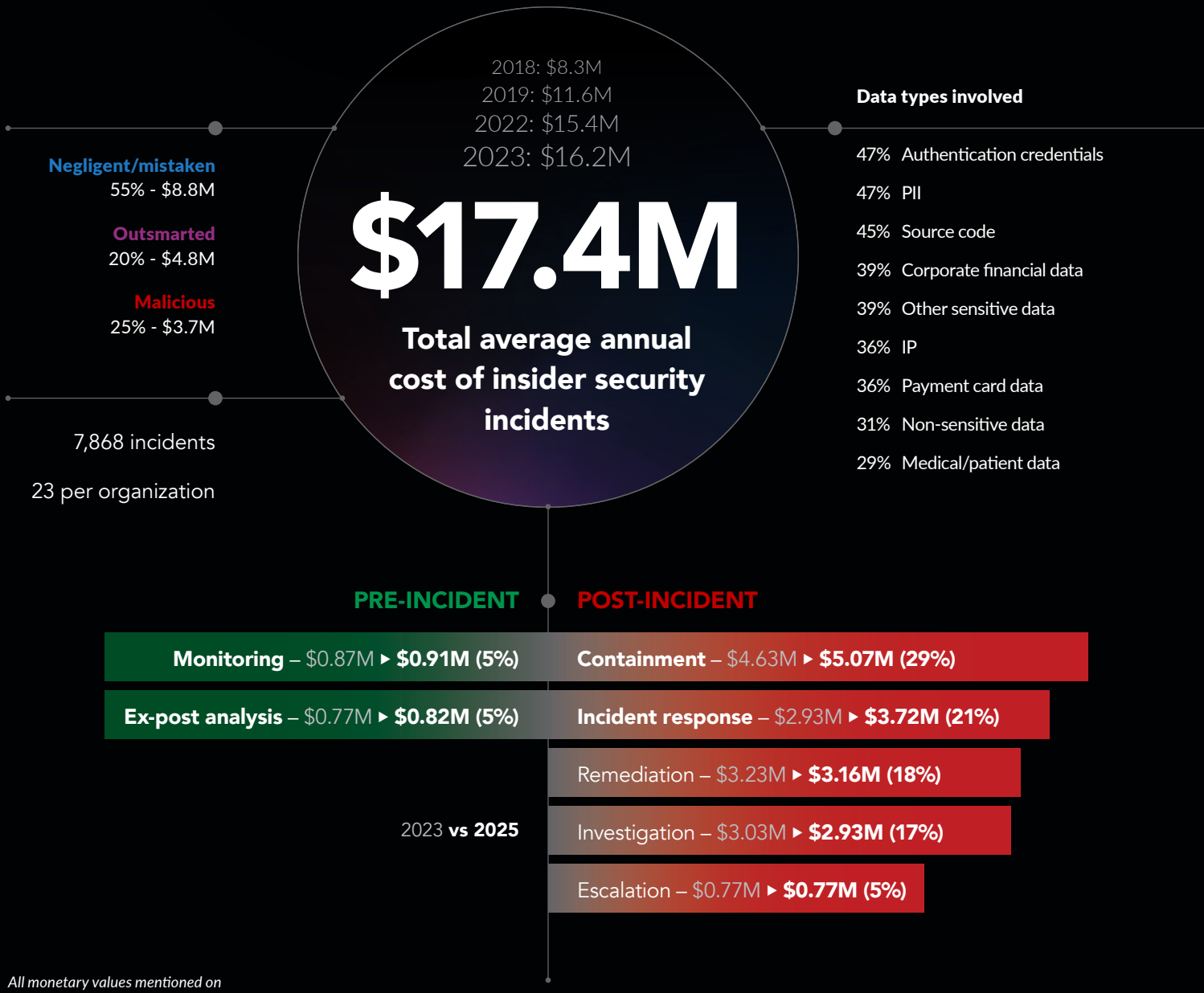
Of those with an insider risk management program, 65% said their program was the only security strategy that effectively enabled them to pre-empt a data breach by detecting insider risk early.

A clear path forward

The cost of insider risk remains significant, but the progress being made is clear. Staying laser focused on proactive measures will be key to achieving protective security and resilience in the years ahead.

THE COST OF INSIDER RISKS CONTINUES TO CLIMB ...

The cost of insider risks continues to rise, driven by escalating post-incident activity costs. However, the growing adoption of insider risk management is delivering clear results. Both the frequency of insider incidents in the 21-40+ range and the average time to containment are declining. Faster resolution significantly reduces costs: **$10.6M for incidents contained in under 31 days versus $18.7M for those lasting over 91 days.**



All monetary values mentioned on this spread are in US dollars (USD).

... BUT INSIDER RISK MANAGEMENT IS STARTING TO PAY OFF

Time to contain declines for the first time

81 days
Average time to contain
DOWN from 86 in 2023

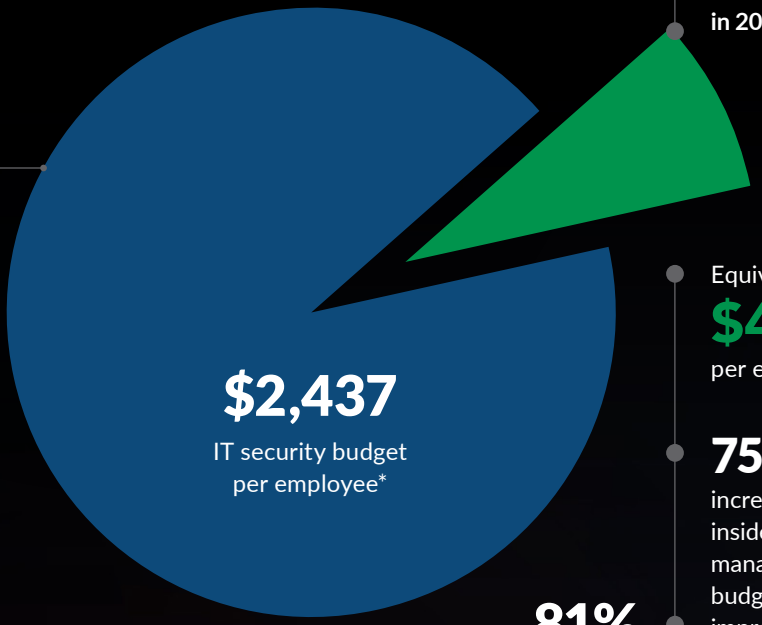
Time saved is money saved

$18.7M at > 91 days
$10.6M at < 31 days

Higher cost, but reduced frequency

57% of companies experienced between 21-40+ incidents
DOWN from 71% in 2023

Companies double investment in insider risk management



16.5%
Insider risk management
UP from 8.2% in 2023

Equivalent to
$402
per employee

75%
increased insider risk management budget to improve ROI on the tech stack and security program

81%
Have or are planning to have an insider risk program
UP from 77% in 2023

Of those with a program, 65% said their program was the only security strategy that enabled them to pre-empt a data breach by detecting insider risk early.

Top reported outcomes of early insider risk detection

63%	61%	59%	59%	48%
Save time responding to a breach	Protect brand reputation	Save money lost in a breach	Avoid regulatory fines	Protect corporate IP and customer PII

** Based on Deloitte Insights: Reshaping the cybersecurity landscape*

KEY FINDINGS

Building on our 2023 research, we surveyed organizations to understand if their priorities and budgets for insider risk management programs have shifted. Our research revealed the following insights.

Organizations are increasingly adopting insider risk management.

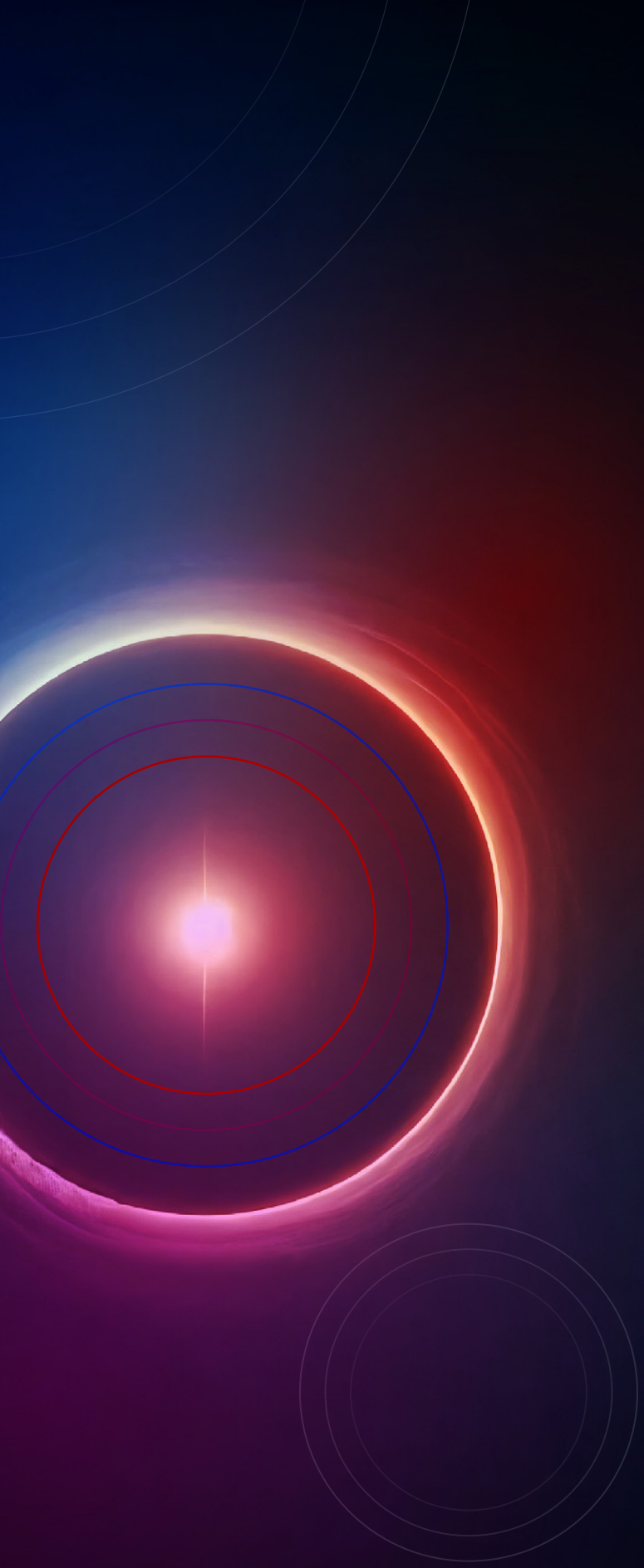
The amount of IT security budget allocated to insider risk management has more than doubled, rising from 8.2% in 2023 to 16.5%. Additionally, 81% of companies now have or plan to have an insider risk management program, up from 77% in 2023.

Companies with an insider risk management program are saving time and money associated with a breach.

When asked the top three outcomes of having an insider risk management program, 63% said saved time in responding to a breach, 61% said protected brand reputation, and 59% said saved money lost in a breach.

For the first time, the time to contain an insider incident has gone down.

The average time to contain an insider incident has reduced to 81 days, down from 86 days in 2023. The faster it takes to contain, the lower the cost ($10.6M for incidents that take less than 31 days, compared with $18.7M for incidents where time to contain exceeds 91 days).



The frequency of insider incidents is decreasing.

Fifty-seven percent of companies are experiencing between 21 and more than 40 incidents per year, down from 71% in 2023.

Companies are betting on bigger insider risk management budgets.

Despite bigger investments in insider risk management, nearly half (45%) say the level of funding is inadequate. Forty-six percent expect a mild to significant increase in funding for insider risk management in 2025.

Post-incident activity costs have climbed significantly, contributing to a higher average annualized cost of insider risk: $17.4M — up from $16.2M in 2023.

The costs of containment ($211,021) and incident response ($154,819) are the most expensive activity cost centers (up from $179,209 and $113,635 in 2023 respectively).

Disruption or downtime and direct and indirect labor represent the most significant consequences of an insider incident.

The consequence of disruption or downtime represents 24% of the cost and 18% is due to direct and indirect labor costs.

Top outcomes of early detection and mitigation of early insider risk detection:



63% Save time responding to a breach

61% Protect brand reputation

59% Save money lost in a breach

59% Avoid regulatory fines

48% Protect corporate IP and customer PII

Top business justifications for having an insider risk management program:



53% Industry standards/ regulations

46% Remote/ hybrid workforce

42% Required by board of directors

40% Required by customers or partners

39% Previous insider threat incident with serious financial consequences

39% Security best practices

36% Taking a proactive approach to security

Three responses permitted.

Top benefits your insider risk management program enables you to achieve that other security strategies cannot:



65%
Pre-empt a data breach by identifying insider risk early in the kill chain

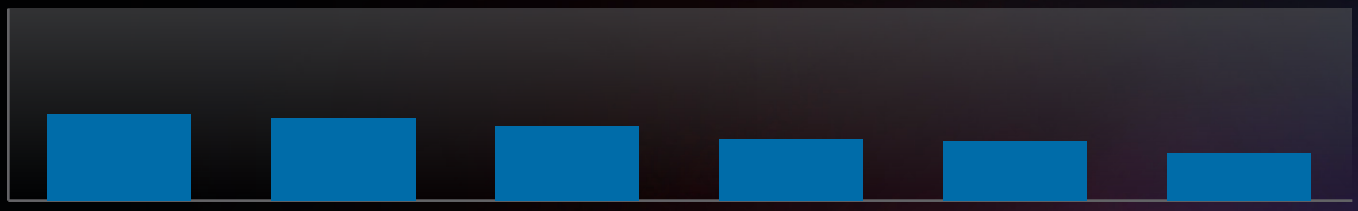
61%
Understand human behavior using AI

59%
Apply a proportionate response to concerning insider behavior (e.g., training and awareness vs. focused observation)

56%
Understand concerning behavior against what's considered normal to the organization

51%
Visibility of potential risk indicators relating to data movement and handling across the environment

Top insider risk management evaluation criteria:



45%
Reduction in incidents

43%
Length of time to resolve an incident

39%
Length of time to investigate an incident

32%
Assessment of the effectiveness of technologies

31%
Assessment of insider risks

25%
Periodic insider risk assessments (i.e., risk quantification)

Three responses permitted.

Cost by Risk Profile



The negligent/mistaken insider causes the most incidents.

Total incidents: 4,321

Total annual: $8.8M
(up from $7.2M in 2023)

Average per organization: 13.5

Per incident cost: $676,517
(up from $505,113 in 2023)



Outsmarted insiders, exploited through credential theft, now represent the most expensive risk.

Total incidents: 1,552

Total annual: $4.8M
(up from $4.2M in 2023)

Average per organization: 4.8

Per incident cost: $779,797
(up from $679,621 in 2023)



Malicious insiders cost on average $715,366 per incident.

Total incidents: 1,995

Total annual: $3.7M
(down from $4.8M in 2023)

Average per organization: 6.3

Per incident cost: $715,366
(up from $701,500 in 2023)

When outsiders compromise insiders

We asked respondents about their experience with external attacks, where outsiders target and exploit trusted insiders to infiltrate organizations.

- Organizations experienced on average 22 external attacks in which an insider was targeted and exploited by an outsider.
- Sixty-eight percent experienced between 11-30 external attacks.
- Sales, HR, and marketing are the top three roles most susceptible to being exploited by an external adversary (47%, 41%, and 40% respectively).
- Functions least likely to be targeted are cybersecurity (18%), IT (23%), legal third-party contractor (23%), and executive c-suite (33%).
- More than half (55%) of credential compromise incidents involved advanced social engineering (such as deep fakes or other AI-generated content).
- Fifty-four percent compromised an insider's personal devices or network to access corporate account information (e.g., password vault), and 47% involved coercion (e.g., blackmail or financial intimidation).

Tech Trends

We also asked respondents about their attitudes towards technology, including consolidation and AI.

The top three technologies deployed across organizations are data loss prevention (56%), user and entity behavior analytics (51%), and user activity monitoring (49%).

Other technologies deployed include endpoint detection and response (48%), privileged access management (47%), security information and event management (45%), and insider risk management (40%).

About half (49%) of organizations agree that technology consolidation of one or more of these technologies is essential or very important.

The top three driving factors, ranked by importance, are cost savings (85%), reduced complexity (64%), and faster detection times (61%), followed by scalability (48%), and actionable data (42%).

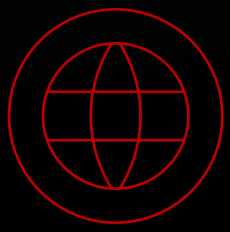
Organizations are increasingly adopting AI to advance their insider risk management programs.

Fifty-four percent of organizations are using AI to detect and prevent insider risks. Of these respondents, 51% say AI and machine learning are essential or very important in the detection and prevention of insider risks. The top three driving factors, ranked by importance, are reduced investigation times (70%), improved behavioral insights (59%), and lowered skillset for insider risk analysts (58%).

Almost half (48%) of companies have a mechanism for ensuring AI use does not violate employee privacy or contribute to bias.

Fifty-two percent communicate AI security and monitoring policies to their employees.

Hardest Hit



Companies in North America spend the most on insider incidents ($22.2M), followed by Europe ($20.3M).



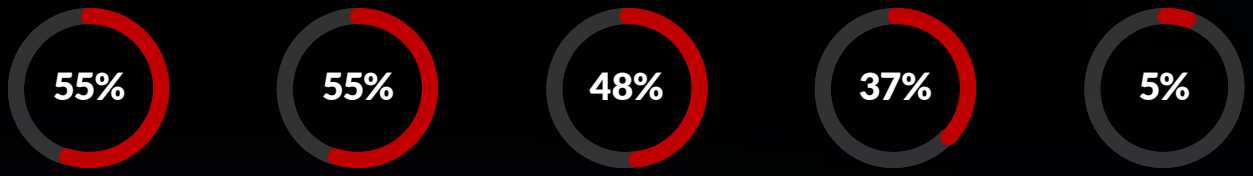
The cost is highest for health and pharma ($29.2M), followed by technology and software ($23M).



Large companies with a headcount of between 25,001 and 75,000 spent an average of $26.2M, while companies with a headcount below 500 spent an average of $7.7M.

Insider Motivations

We asked respondents to identify the top two psychological motivations behind insider risks that concern them the most.



Financial gain

Convenience (e.g., using AI or LLMs to support job tasks)

Professional grievances (e.g., employee dissatisfaction or disgruntlement)

Nationalism

Other

Five signs that your organization is at risk:

1. Employees are not trained to fully understand and apply laws, mandates, or regulatory requirements to their work and affect the organization's security.
2. Employees are unaware of the steps they should take at all times to ensure the devices they use (both company issued and BYOD) are secured at all times.
3. Employees are sending highly confidential data to an unsecured location in the cloud.
4. Employees circumvent the organization's security policies to simplify tasks.
5. Employees do not keep devices and services patched and upgraded to the latest versions at all times.

ABOUT THIS STUDY

Our research focuses on actual insider-related events or incidents that impact organizational costs over the past 12 months.

Our methods attempt to capture both direct and indirect costs including but not limited to the following business risks:

- Theft or loss of mission-critical data or intellectual property
- Impact of downtime on organizational productivity
- Damages to equipment and other assets
- Cost to detect and remediate systems and core business processes
- Legal and regulatory impact, including litigation defense costs
- Lost confidence and trust among key stakeholders
- Diminishment of marketplace brand and reputation

This research utilizes an activity-based costing (ABC) framework. Our fieldwork was conducted over a two-month period concluding in November 2024. Our final benchmark sample consisted of 349 separate organizations. A total of 8,306 interviews were conducted with key personnel in these organizations. Activity costs for the present study were derived from actual meetings or site visits for all participants conducted under strict confidentiality. Targeted organizations were:

- Commercial and public sector organizations
- Global headcount of less than 500 or more employees
- Locations throughout the following regions: North America, Europe, Middle East and Africa, and Asia-Pacific
- Central IT function with control over on-premises and/or cloud environment
- Experienced one or more material incidents caused by negligent/mistaken, malicious/criminal, or outsmarted insiders

In this report, we present an objective framework that measures the full cost impact of events or incidents caused by insiders. Following are the three case profiles that were used to categorize and analyze insider-related cost for 349 organizations:

- Negligent or mistaken employee or contractor
- Malicious or criminal insider including employee or contractor malice
- Outsmarted employee (i.e., credential theft)

Our first step in this research was the recruitment of global organizations. The researchers utilized diagnostic interviews and activity-based costing to capture and extrapolate cost data. Ponemon Institute executed all phases of this research project, which included the following steps:

- Working sessions with DTEX Systems to establish areas of inquiry
- Recruitment of benchmark companies
- Development of an activity-based costing framework
- Administration of research program
- Analysis of all results with appropriate reliability checks
- Preparation of a report that summarizes all salient research findings

ANALYSIS AND SCOPE OF THE INSIDER RISK PROBLEM

Trends in the insider risk benchmark research

Since 2018, insider incidents and the number of organizations in the research have both more than doubled. Table 1 provides a retrospective of the research and how insider risks have impacted organizations.

TRENDS IN HOW INSIDER RISKS HAVE IMPACTED ORGANIZATIONS	FY2018	FY2019	FY2022	FY2023	FY2024
Total number of incidents discovered	3,269	4,458	6,803	7,343	**7,868**
Incidents per company	21	20.8	24.4	23.7	**22.5**
Average number of interviews per group	20	21	20.8	24.5	**23.8**
Average number of benchmarked organizations	156	214	278	309	**349**

Table 1

Frequency of 7,868 incidents by insider risk profile

Negligent employees or contractors continue to be the primary source of an insider-related incident. Figure 1 shows the distribution of 7,868 reported attacks analyzed in our sample. A total of 4,321 attacks (55%) were caused by employee or contractor negligence/mistakes. Criminal or malicious insiders caused another 1,995 attacks (25%) and there were 1,552 credential thefts caused by outsmarted insiders (20%).

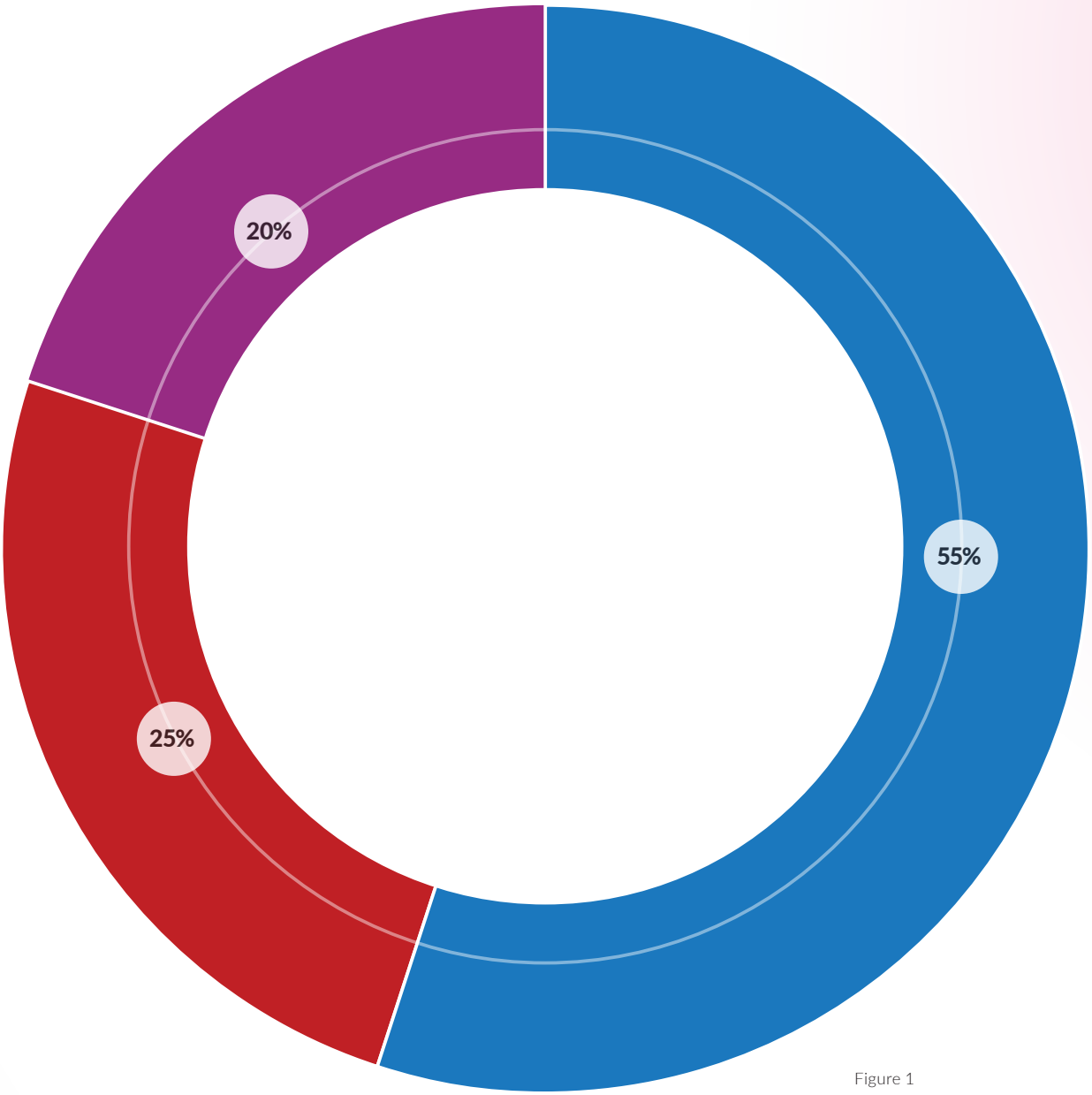


Figure 1

Negligent or mistaken insiders
Outsmarted insiders (credential theft)
Malicious or criminal insiders

Frequency for three profiles of insider incidents

Employee negligence or mistakes remain the most common insider incidents but have seen a slight decline. As shown in Figure 2, incidents resulting from employee or contractor negligence or mistakes decreased from 14.2 in 2023 to 13.5 in 2024. Criminal and malicious insider incidents decreased from 6.9 to 6.3. Credential theft has decreased from an average of 6.2 incidents in 2023 to 4.8 incidents in this year's study.

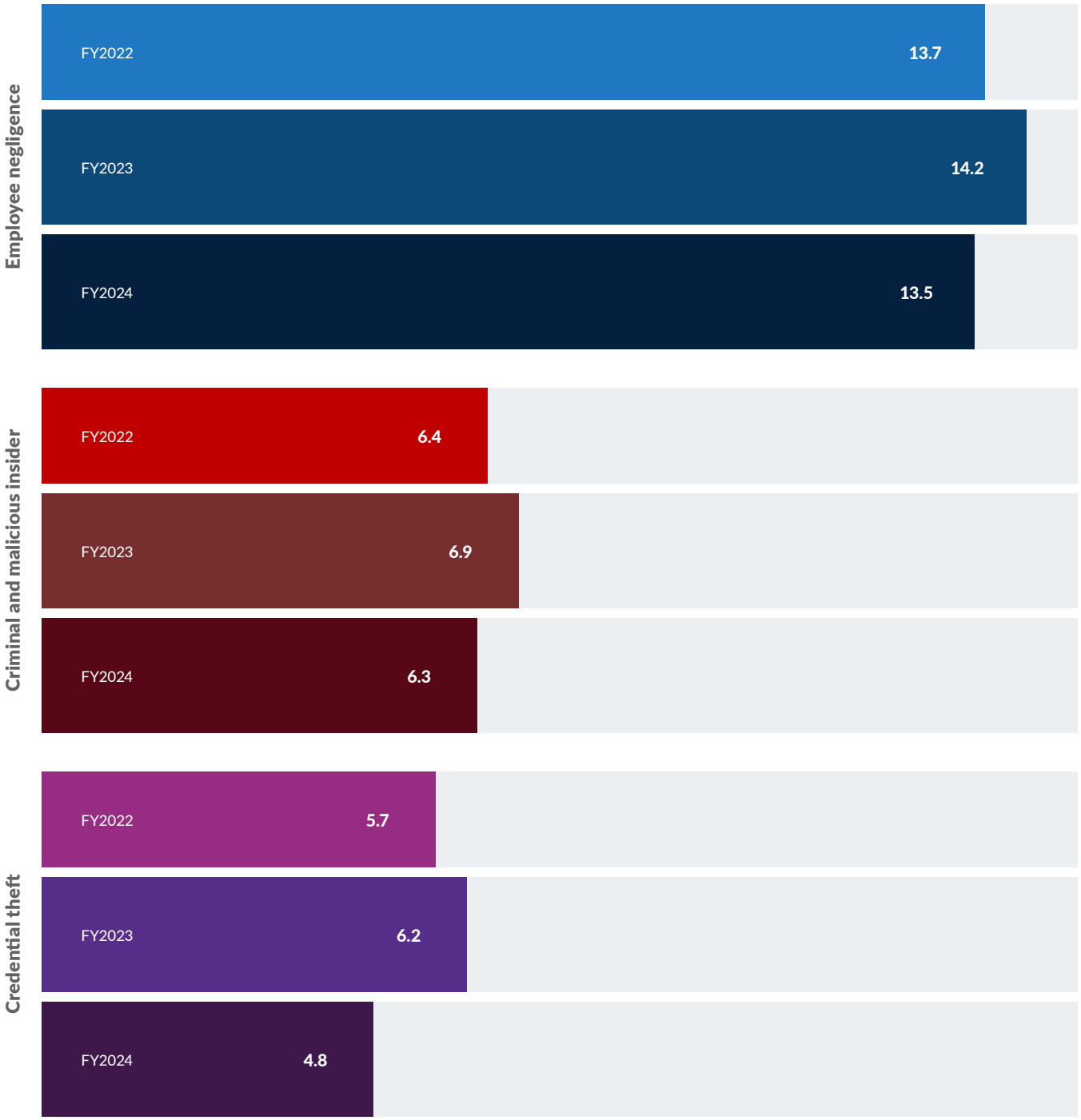


Figure 2

THE COST OF INSIDER RISK

Average cost per incident and annualized cost from 2022 to 2024

Employee negligence or mistakes continue to be the costliest types of incidents. As shown in Table 2, the annualized cost has steadily increased from $15.4M in 2022 to $17.4M in 2024. While the average number of employee negligent or mistaken incidents have decreased slightly, the average cost to remediate such an incident increased from $505,113 in 2023 to $676,517 in 2024.

FY2022 CASE PROFILES	Average cost per incident	Number of incidents	Annualized cost
Negligent or mistaken insider	$484,931	13.7	$6,643,555
Criminal or malicious insider	$648,062	6.4	$4,147,597
Outsmarted insider (credential theft)	$804,997	5.7	$4,588,483
			$15,379,635

FY2023 CASE PROFILES	Average cost per incident	Number of incidents	Annualized cost
Negligent or mistaken insider	$505,113	14.2	$7,172,605
Criminal or malicious insider	$701,500	6.9	$4,840,350
Outsmarted insider (credential theft)	$679,621	6.2	$4,213,650
			$16,226,605

FY2024 CASE PROFILES	Average cost per incident	Number of incidents	Annualized cost
Negligent or mistaken insider	$676,517	13.5	$8,828,292
Criminal or malicious insider	$715,366	6.3	$3,719,898
Outsmarted insider (credential theft)	$779,707	4.8	$4,834,190
			$17,382,380

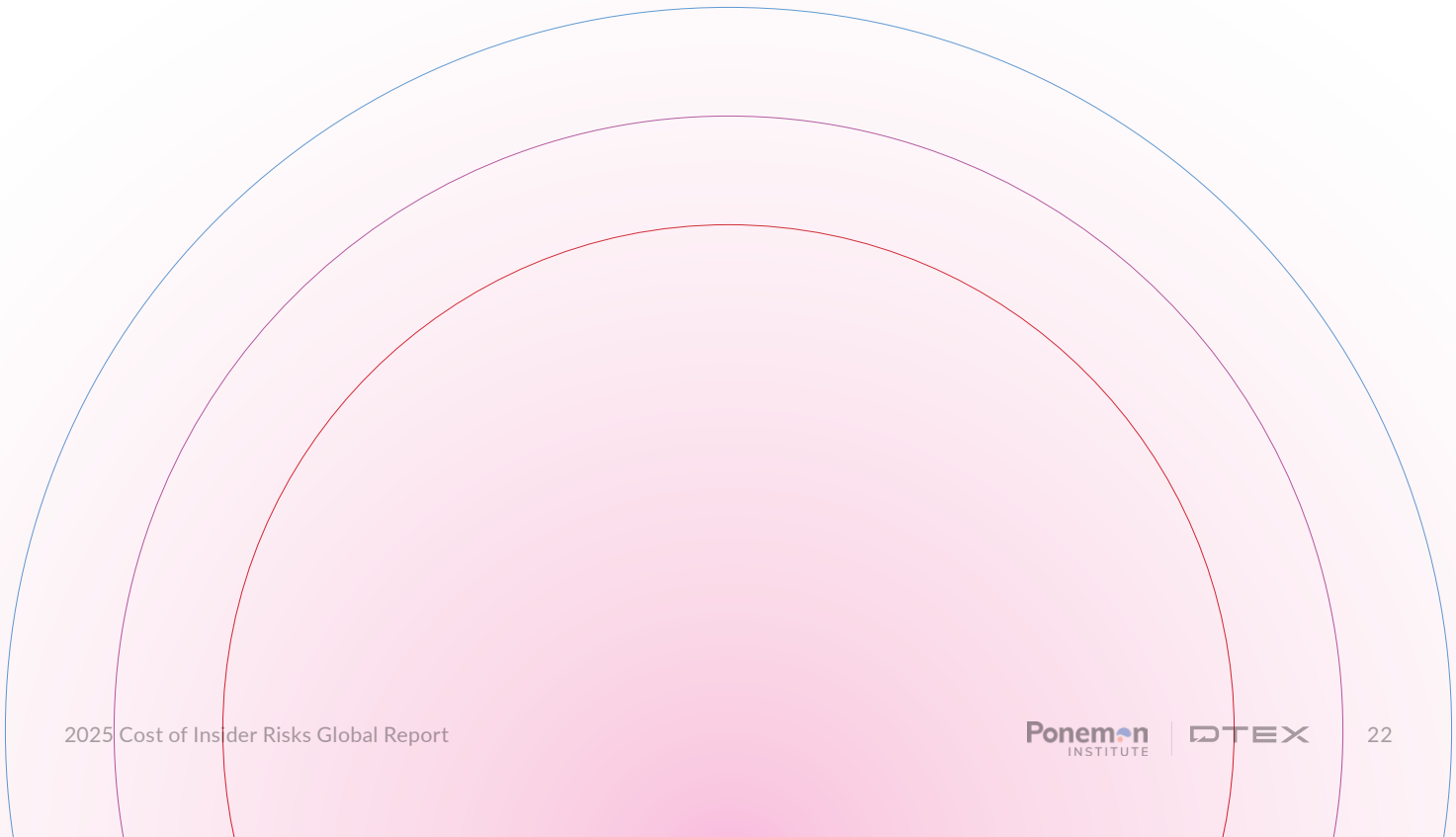
Table 2. US$ millions

Frequency of insider-related incidents by organizations over five years

Organizations having between 21 and more than 40 incidents decreased. Table 3 shows the average consolidated frequency of employee/contractor negligence or mistakes, criminal or malicious incidents, and outsmarted incidents (credential theft) per company. According to the 2023 research, 71% of organizations (30% + 22% + 19%) experienced between 21 and more than 40 incidents. In 2024, 57% (26% + 21% + 10%) had between 21 and more than 40 incidents.

FREQUENCY OF INSIDER INCIDENTS PER ORGANIZATION	FY2018	FY2019	FY2022	FY2023	FY2024
1 to 10	29%	25%	19%	18%	25%
11 to 20	18%	16%	14%	11%	18%
21 to 30	26%	29%	31%	30%	26%
31 to 40	19%	19%	21%	22%	21%
More than 40	8%	11%	15%	19%	10%
Total	**100%**	**100%**	**100%**	**100%**	**100%**

Table 3



Average incident frequency by four global regions

In 2024, organizations in the Middle East experienced the most insider incidents (14.9) and Asia-Pacific had the least number of incidents (11.3). Figure 3 presents the frequency of insider incidents in the four regions represented in the research. In all regions, incidents resulting from employee or contractor negligence or mistakes occurred the most frequently. Organizations in North America are most likely to experience credential theft, which is a costly source of insider risk.

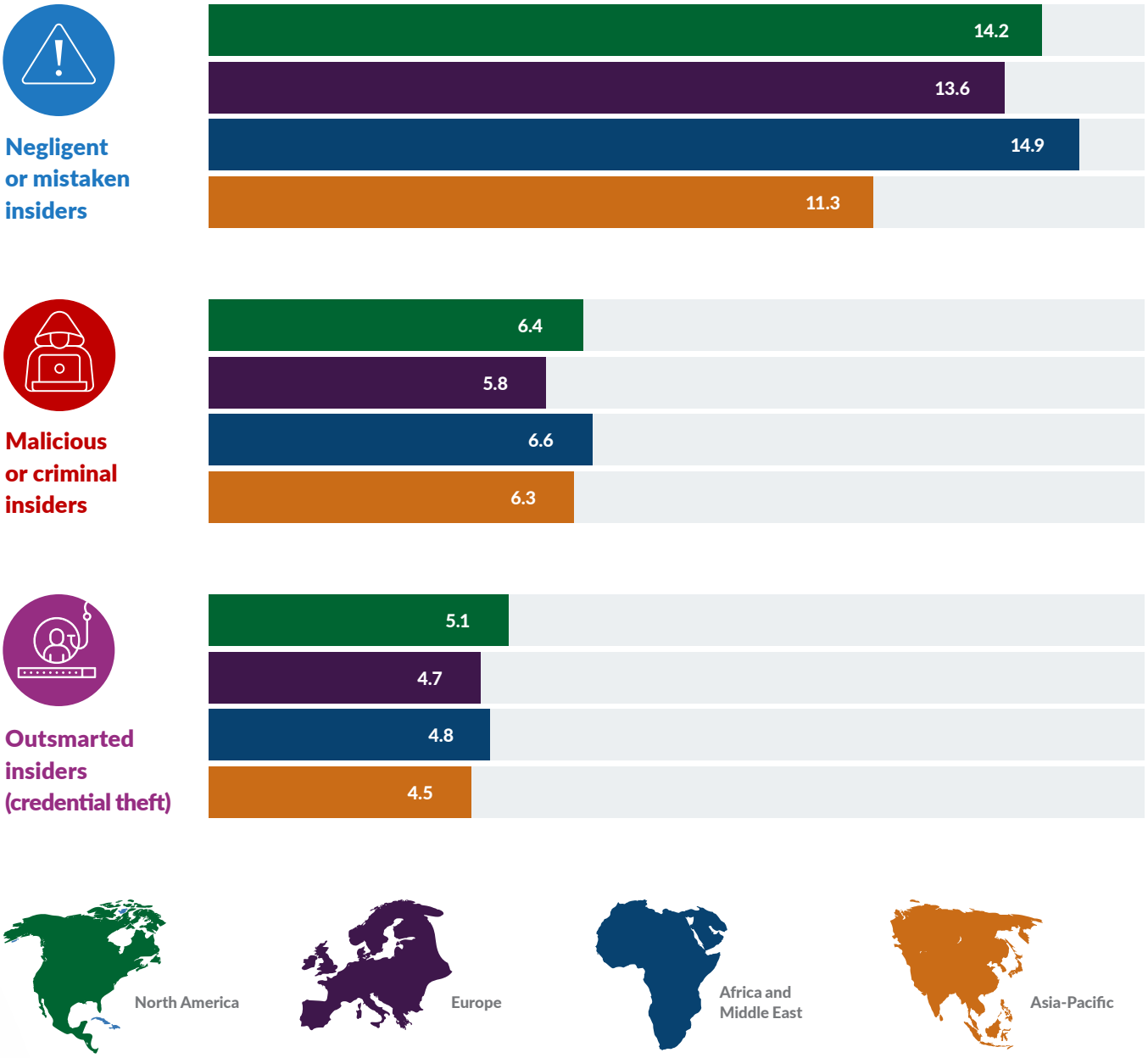


Figure 3

Average percentage of how long it takes to contain an insider incident based on the average time of 81 days to contain

Companies are spending an average of 81 days to contain one insider security incident. According to Figure 4, 35% of insider incidents took an average of more than 91 days to contain. Thirty-two percent say it took an average of 61 to 91 days. Only 12% of incidents were contained in less than 31 days.



Figure 4

More than 91 days
61-91 days
31-61 days
Less than 31 days

Average cost by days to contain

The longer it takes to contain an insider incident, the more costly it is to remediate. As shown in Figure 5, if it takes more than 91 days, the average cost is $18.7M. If it takes less than 31 days, the average cost is $10.6M.



Figure 5. US$ millions

Percentage frequency in the use of tools and activities

Most participating organizations (76%) are using data loss prevention to reduce insider risks. Seventy-five percent have user training and awareness programs. Least used are strict third-party vetting procedures (37%), network traffic intelligence, and incident response management (both 40%), as shown in Figure 6.

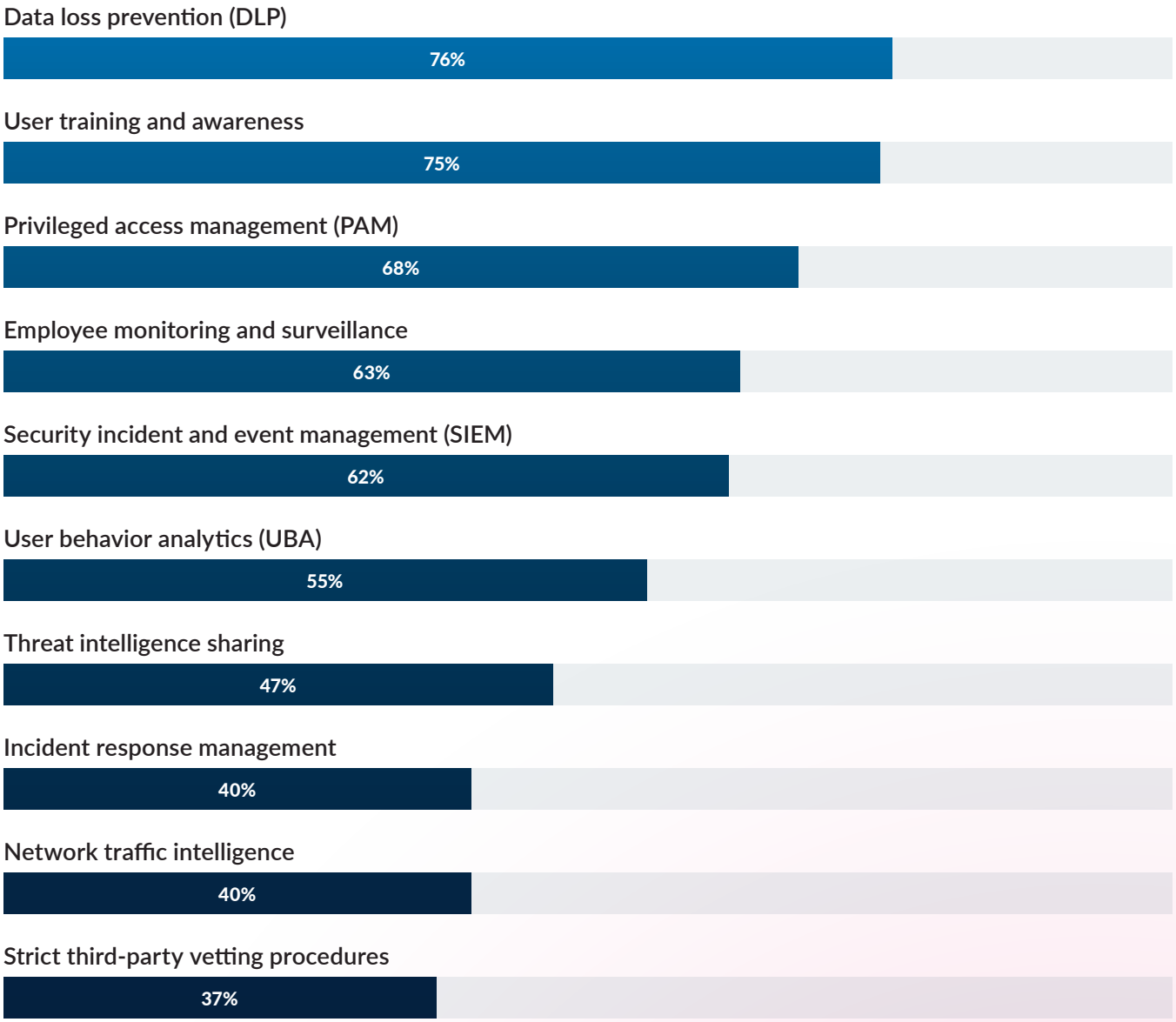


Figure 6. US$ millions

Cost savings resulting in the deployment of security technologies and activities

User training and awareness programs are used by most companies and are shown to reduce insider costs significantly. Figure 7 presents the tools and activities companies deploy to reduce the occurrence of insider risks and the cost savings for each given item.

The technology that reduces cost the most is user training and awareness programs ($5.2M) followed by privileged access management solutions ($4.8M).

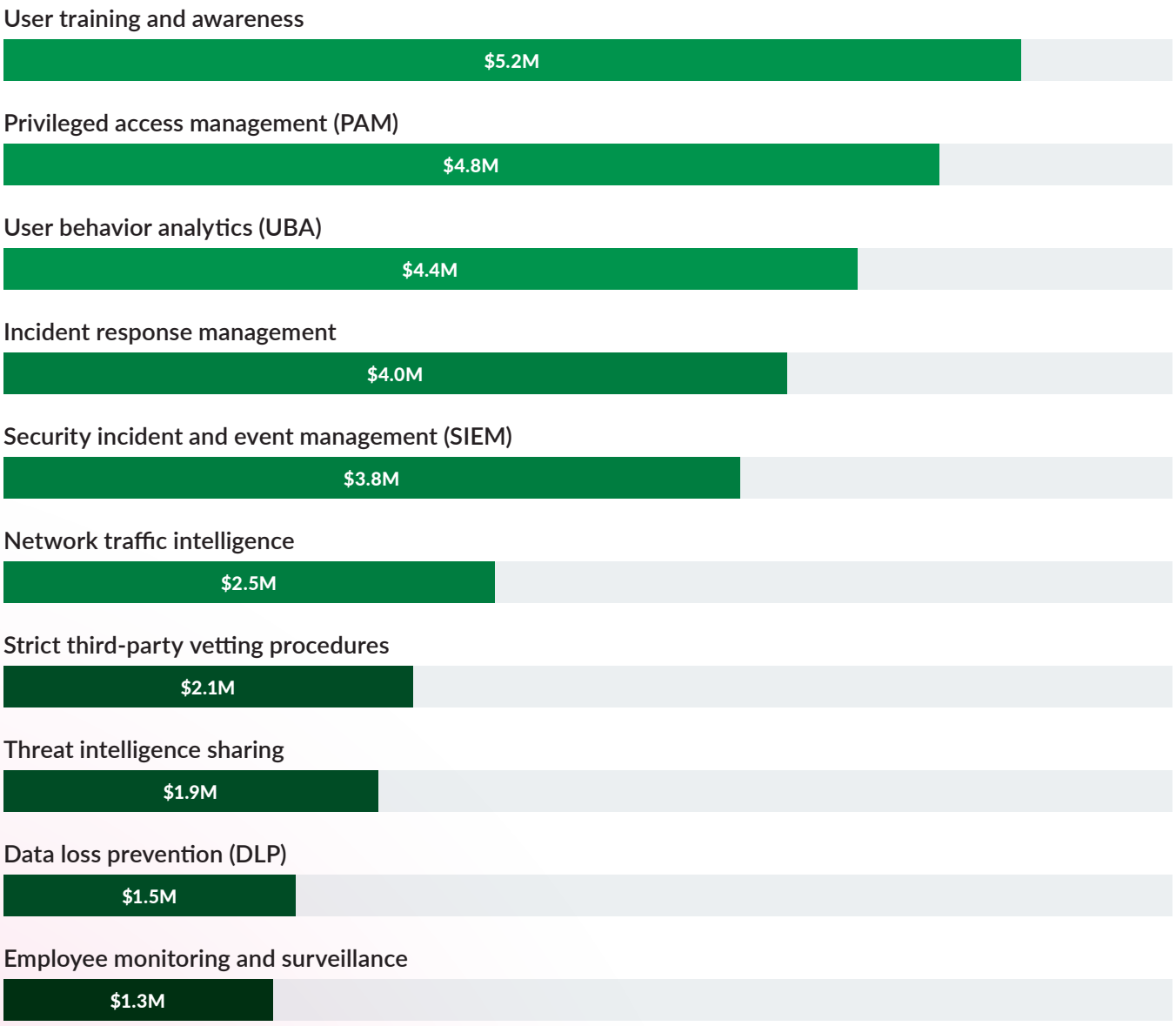


Figure 7. US$ millions

Percentage of insider incident cost by consequence to organizations

Disruption or downtime and technologies represent the most significant financial consequences when dealing with insider incidents. Figure 8 reports the percentage of insider cost for careless or negligent employees, criminal or malicious insiders, and credential theft according to the seven cost categories: Disruption cost (downtime), direct and indirect labor, technology, cash outlays, process/workflow changes, revenue losses, and overhead.

The three largest costs by consequences are the impact of business disruption due to diminished employee/user productivity (24% of total cost), direct and indirect labor (18% of total cost) and technology (23% of total cost), which includes the amortized value and the licensing for software and hardware that are deployed in response to insider-related incidents.

Process costs (13%) include governance and control system activities in response to threats and attacks. Overhead (3%) includes a wide array of miscellaneous costs incurred to support personnel as well as the IT security infrastructure.



Figure 8

Total incidents in ascending order by headcount (size)

The larger the organization, the more insider incidents. Figure 9 shows the distribution of insider incidents in ascending order by headcount or size of the participating companies. As can be seen, the upward slope suggests that the frequency of insider incidents is positively correlated with organizational size. The correlation is most salient for larger-sized companies.

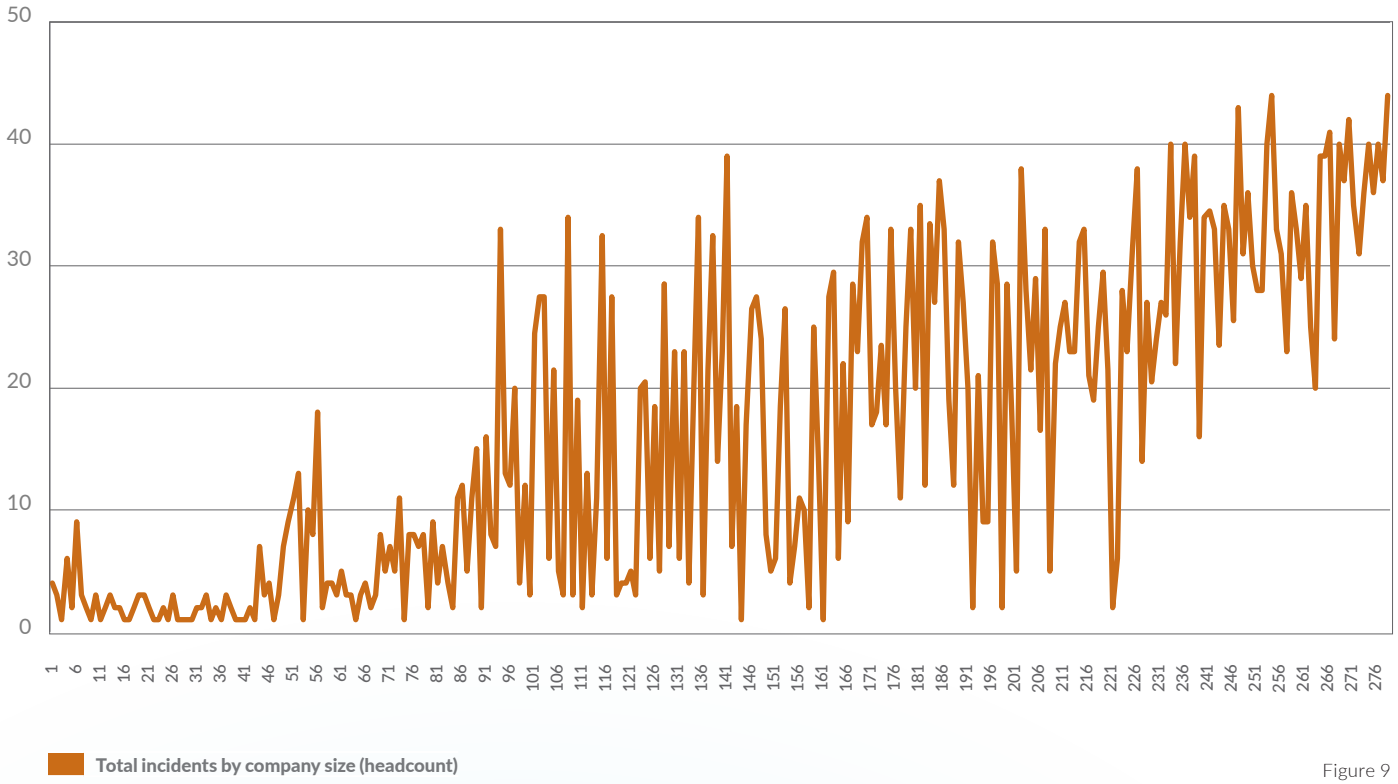


Figure 9

THE COST OF INSIDER RISK BY ACTIVITY

This study addresses the core process-related activities that drive a range of expenditures or costs associated with a company's response to insider-related incidents[1].

The seven cost activity centers in our framework are defined as follows:

1. **Monitoring and surveillance:** Activities that enable an organization to reasonably detect and possibly deter insider incidents or attacks. This includes allocated (overhead) costs of certain enabling technologies that enhance mitigation or early detection.

2. **Investigation:** Activities necessary to thoroughly uncover the source, scope, and magnitude of one or more incidents.

3. **Escalation:** Activities taken to raise awareness about actual incidents among key stakeholders within the company. The escalation activity also includes the steps taken to organize an initial management response.

4. **Incident response:** Activities relating to the formation and engagement of the incident response team including the steps taken to formulate a final management response.

5. **Containment:** Activities that focus on stopping or lessening the severity of insider incidents or attacks. These include shutting down vulnerable applications and endpoints.

6. **Ex-post analysis:** Activities to help the organization minimize potential future insider-related incidents and attacks. It includes steps to communicate with key stakeholders both within and outside the company, including the preparation of recommendations to minimize potential harm.

7. **Remediation:** Activities associated with repairing and remediating the organization's systems and core business processes. These include the restoration of damaged information assets and IT infrastructure.

1. Internal costs are extrapolated using labor (time) as a surrogate for direct and indirect costs. This is also used to allocate an overhead component for fixed costs such as multi-year investments in technologies.

Average cost of seven activities in 2023 and 2024

The cost to contain an insider security incident increased significantly from 2023. As discussed, the average time to contain an incident is 81 days in this year's research. Table 4 summarizes the average cost of insider-related incidents for seven activities. As shown, containment and incident response represent the most expensive activities at $211,021 (an increase from $179,209 in 2023) and $154,819 (an increase from $113,635 in 2023), respectively. Least expensive are ex-post analysis and escalation at $34,290 and $32,242, respectively.

ACTIVITY COST CENTER CATEGORIES	FY2023	FY2024
Containment	$179,209	$211,021
Incident response	$113,635	$154,819
Remediation	$125,221	$131,761
Investigation	$117,504	$121,974
Monitoring and surveillance	$33,596	$37,756
Ex-post analysis	$29,787	$34,290
Escalation	$29,794	$32,242
Total	**$628,746**	**$723,863**

Table 4. US$ millions

Percentage net increase in average cost for seven activities from FY2023 to FY2024

Since 2023 it has become more costly to respond to an insider incident. As shown in Figure 10, incident response costs increased by 31%. Remediation and investigation increased the least.

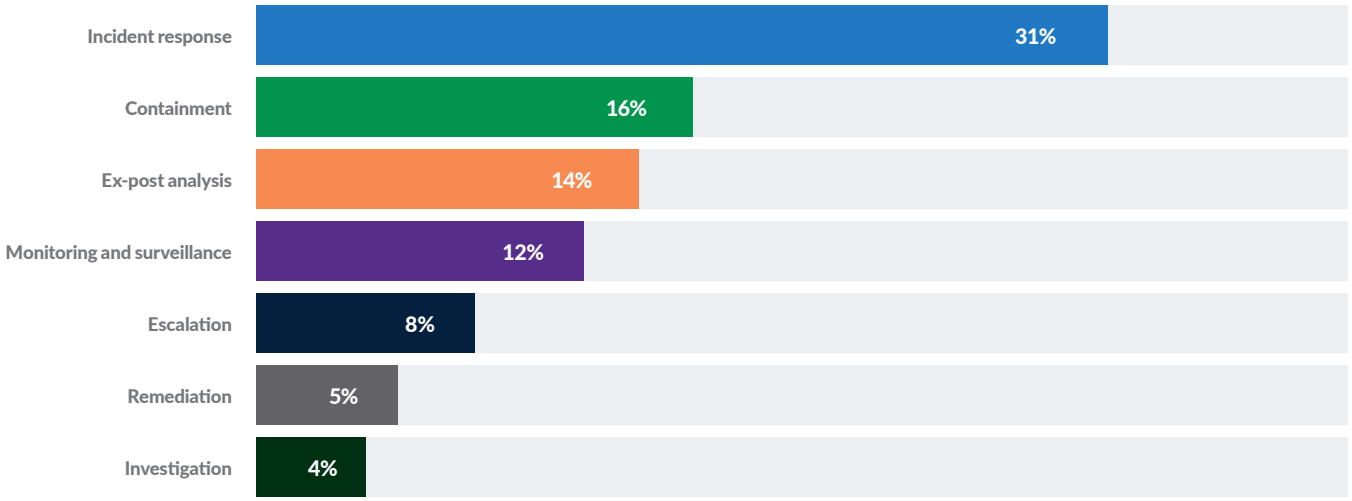


Figure 10

Cost for seven activities by type of incident

Activity cost centers	Negligent or mistaken	Malicious or criminal	Outsmarted (credential theft)	Average cost
Monitoring and surveillance	$18,437	$40,240	$54,590	$37,756
Investigation	$84,123	$137,300	$144,500	$121,974
Escalation	$22,826	$41,300	$32,600	$32,242
Incident response	$205,039	$130,301	$129,117	$154,819
Containment	$188,358	$201,505	$243,200	$211,021
Ex-post analysis	$31,550	$30,120	$41,200	$34,290
Remediation	$126,184	$134,600	$134,500	$131,761
Total	**$676,517**	**$715,366**	**$779,707**	**$723,863**

US$ millions

Average activity cost per incident by insider type in 2024

The average activity cost is highest for outsmarted insiders (i.e., credential theft). Figure 11 demonstrates the significant difference in activity costs between credential theft and employee negligence/mistakes.



Figure 11. US$ millions

Activity costs by global region

North American companies are spending significantly more than the average cost of insider incidents to deal with insider risks. The total average cost of activities to resolve insider incidents over a 12-month period is $17.4M. As shown in Figure 12, companies in North America experienced the highest total cost at $22.2M. European companies had the next highest cost at $20.3M. Asia-Pacific had an average cost much lower than the average total cost for all 349 companies ($13M).

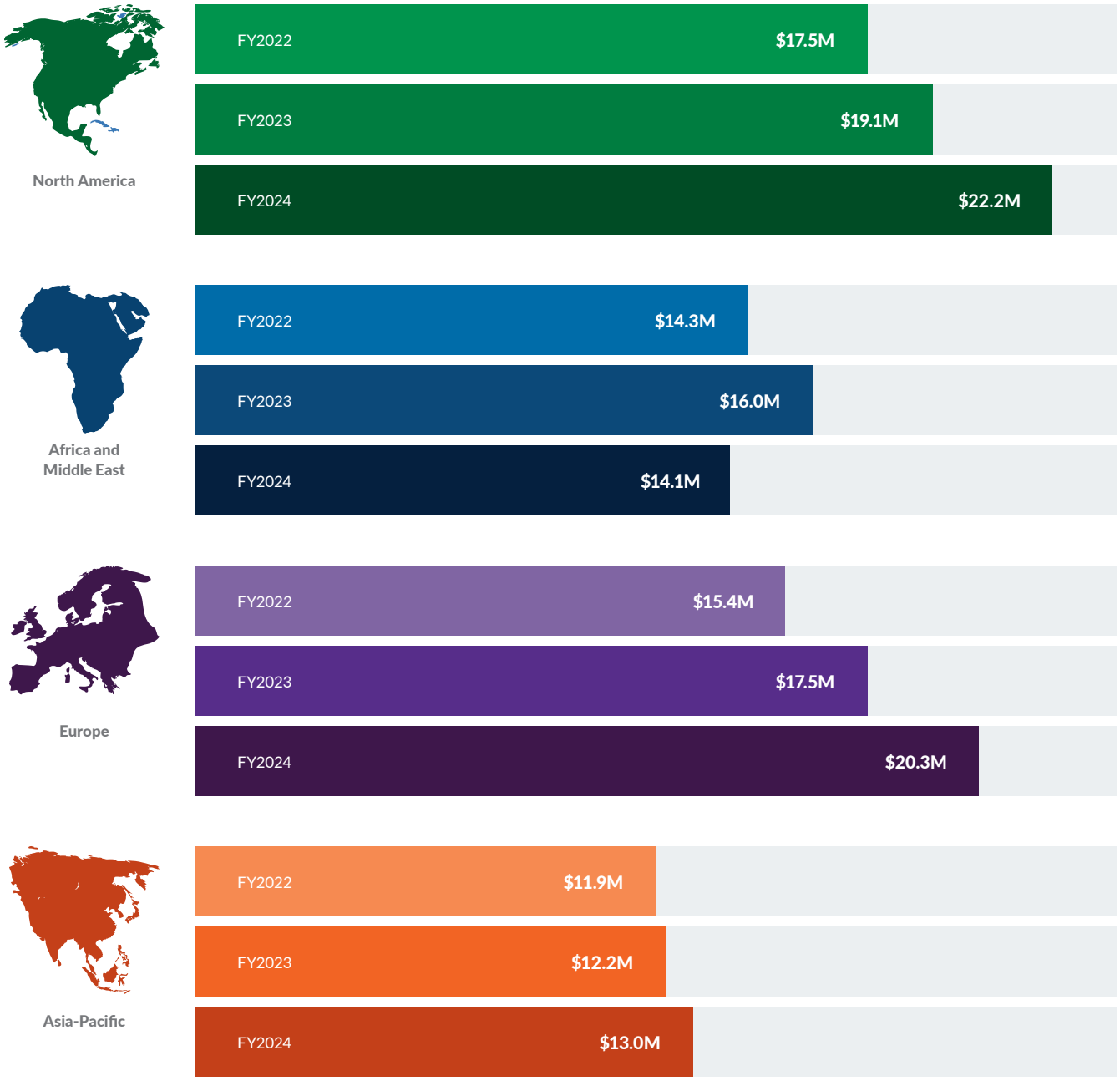


Figure 12. US$ millions

Average activity cost by headcount

Larger organizations spend the most on the activities to resolve an insider risk incident. As shown in Figure 13, organizations with a headcount of between 25,000 and 75,000 are spending significantly more on activities needed to resolve the incident, an average of $26.2M. Organizations with a headcount of less than 500 spent an average of $7.7M.

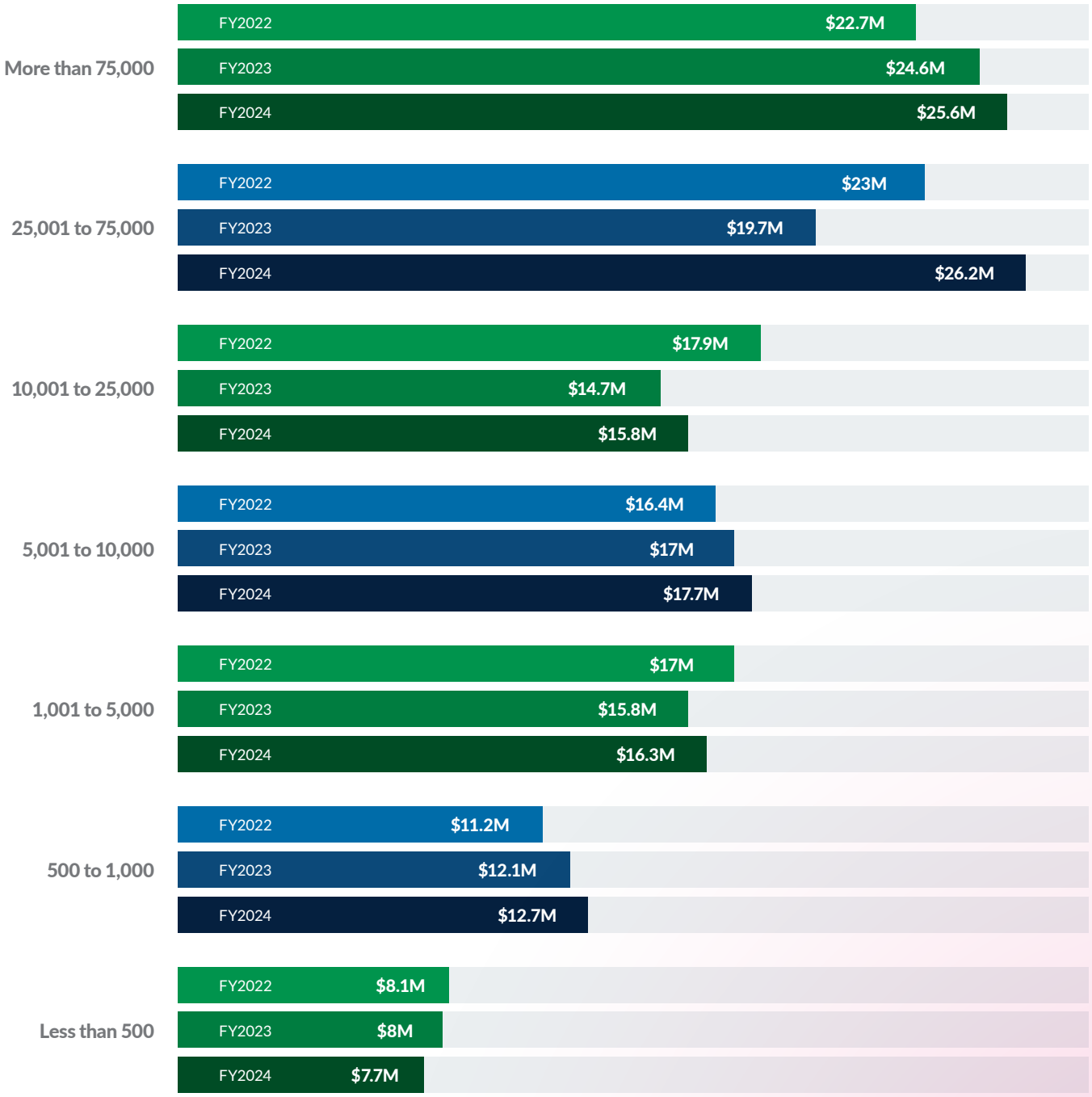


Figure 13. US$ millions

Average cost by days to contain the incidents

The faster containment occurs, the lower the activity cost. The total annualized cost appears to be positively correlated with the time to contain insider-related incidents. As shown in Figure 14, incidents that took more than 91 days to contain had the highest average total cost per year ($18.7M). In contrast, incidents that took less than 31 days to contain had the lowest total cost ($10.6M). The average annual cost is $17.4M.



Figure 14. US$ millions

FY2022 mean = $15.4 (US$ millions)
FY2023 mean = $16.2 (US$ millions)
FY2024 mean = $17.4 (US$ millions)

Percentage cost of insider incidents by activity centre

Containment accounts for 31% of all costs. The following pie chart shows the percentage cost for seven activity centers. According to Figure 15, containment represents 31% of total annualized insider-related activity costs. Activities relating to incident response represent 23% of the cost.

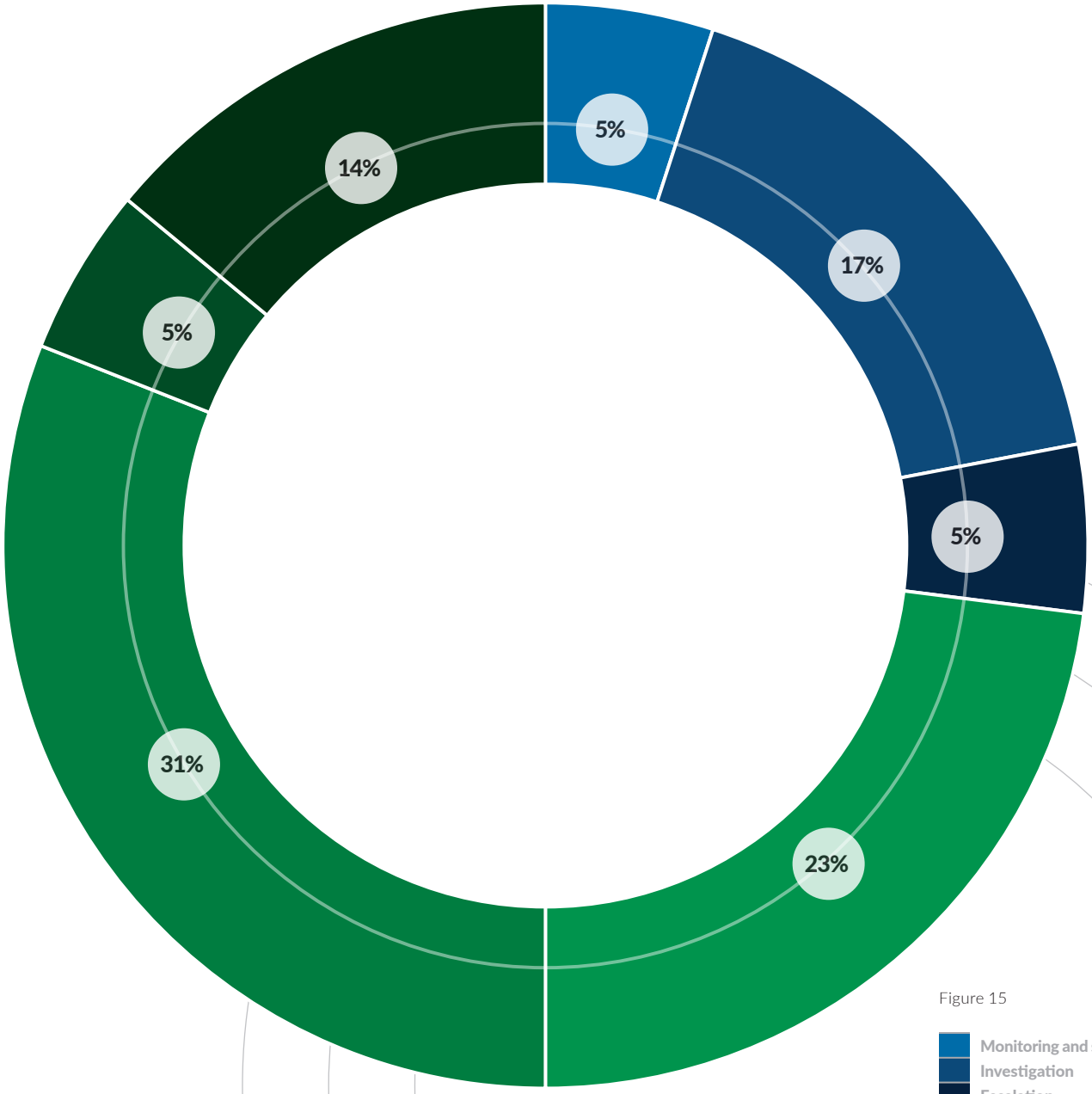


Figure 15

Monitoring and surveillance
Investigation
Escalation
Incident response
Containment
Ex-post analysis
Remediation

Annualized activity cost by industry

Activity costs are highest for health and pharma followed by technology and software. According to Figure 16, the average activity cost for health and pharma is $29.2M and technology and services is $23M, much higher than the average annualized cost of $17.4M.

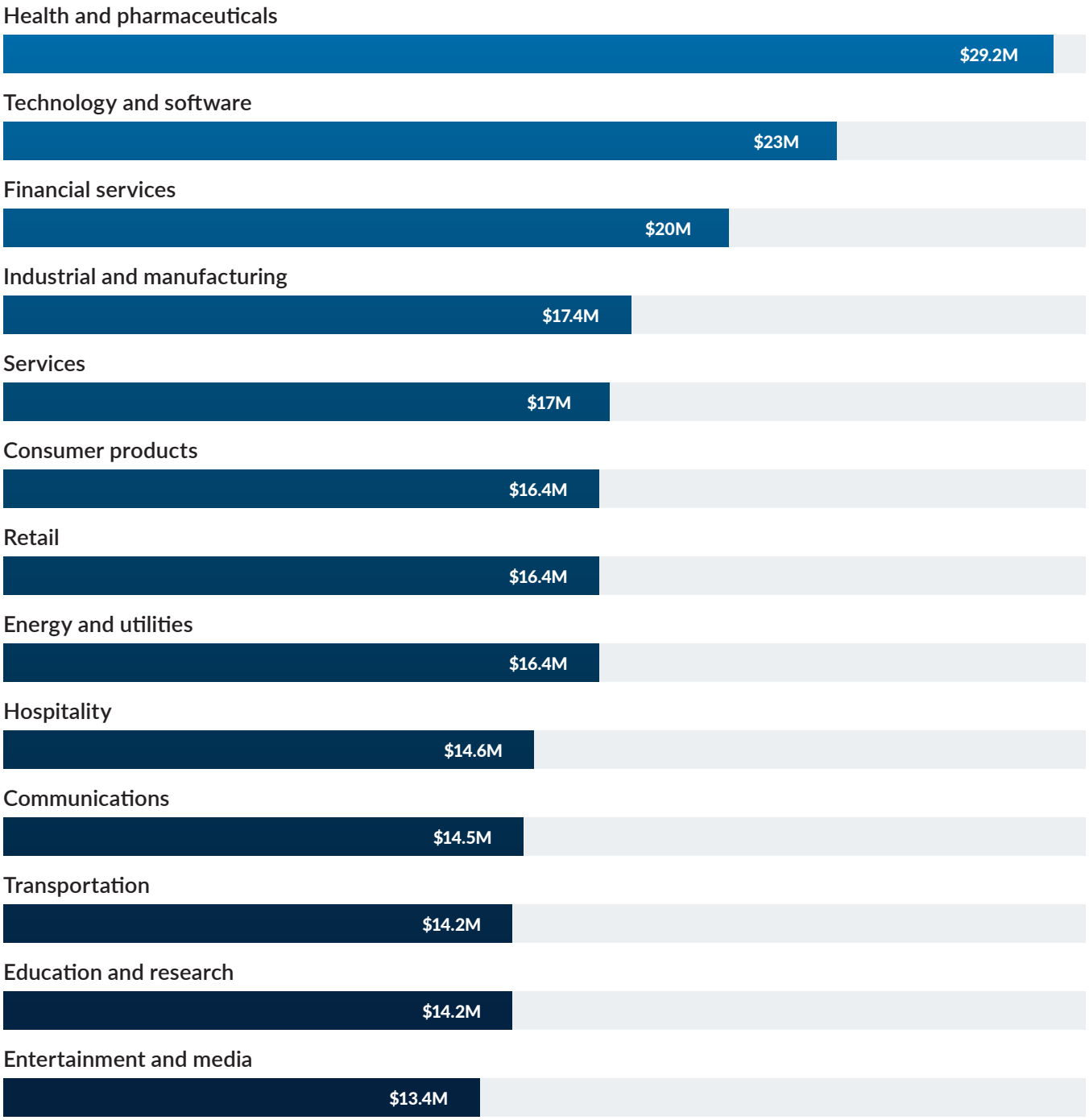


Figure 16. US$ millions

Percentage of direct vs. indirect costs for activity centers

Companies were asked to estimate the direct and indirect costs spent to accomplish a given activity. Direct costs are the direct expense outlay to accomplish a given activity and indirect costs are the amount of time, effort, and other organizational resources spent, but not as a direct cash outlay.

Figure 17 shows the proportion of direct and indirect costs[2] for seven internal activity cost centers. As can be seen, the cost for monitoring and surveillance and remediation have the highest percentage of direct cost (61% and 53%, respectively). The highest percentage of indirect cost for activities are for incident response and ex-post analysis (58% and 57%, respectively).

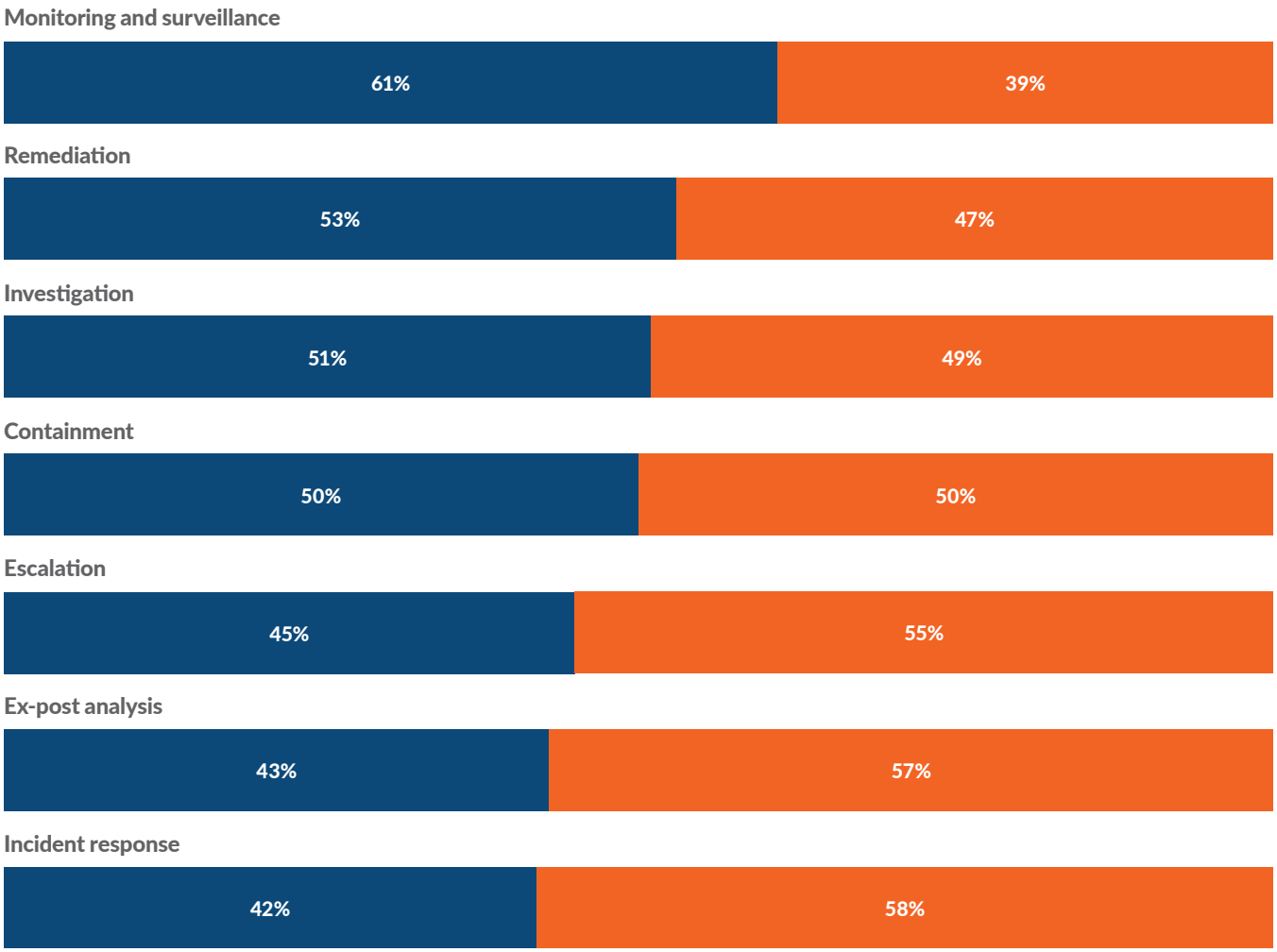


Figure 17

2. The direct cost is what is spent to accomplish a given activity and indirect costs are the amount of time, effort, and other organizational resources spent to resolve the incident.

MANAGING THE INSIDER RISK

The insider incidents that cause the most concern

In addition to determining the cost of insider risks for companies in this research, we interviewed participants about their experiences and what they are doing to reduce risks. Whenever possible in this analysis, findings from the 2024 research are compared to the 2023 report.

Of all the types of insider risks in this research, organizations continue to be most concerned about a criminal or malicious insider. According to Figure 18, 34% of respondents say they are most concerned about a malicious insider stealing sensitive and confidential data. This is followed by 27% of respondents who say they worry about an outsmarted insider who was exploited by an external attack or adversary. The concern about a negligent insider who caused harm through carelessness or inattentiveness increased from 15% of respondents in 2023 to 22% in 2024.

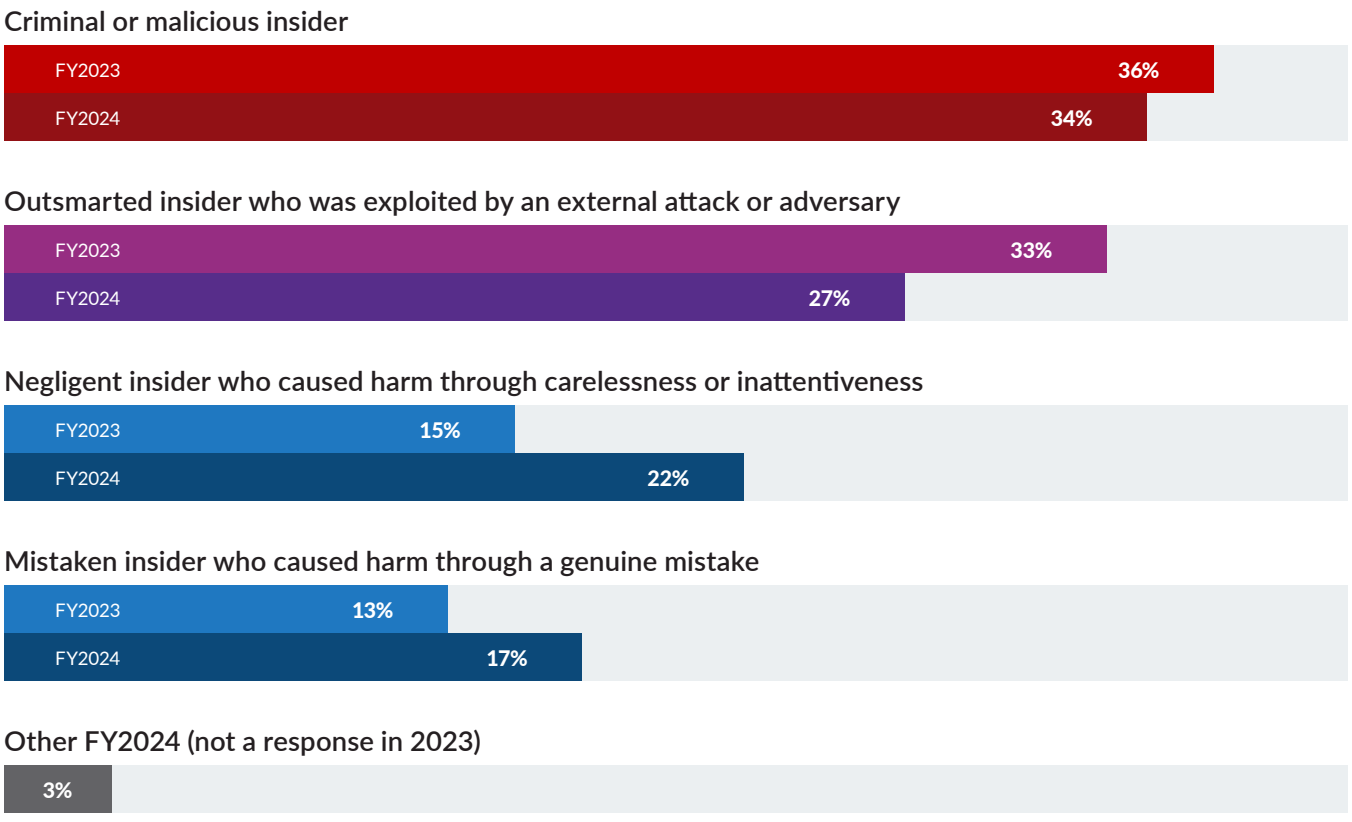


Figure 18

Insider incidents by behaviors

As reported, the most insider incidents involve employee negligence (55%). Of these organizations, as shown in Figure 19, 63% of respondents say the insider incidents involved an employee's inadvertent or accidental behavior. Fifty percent say a malicious outsider stole data by compromising insider credentials or accounts.

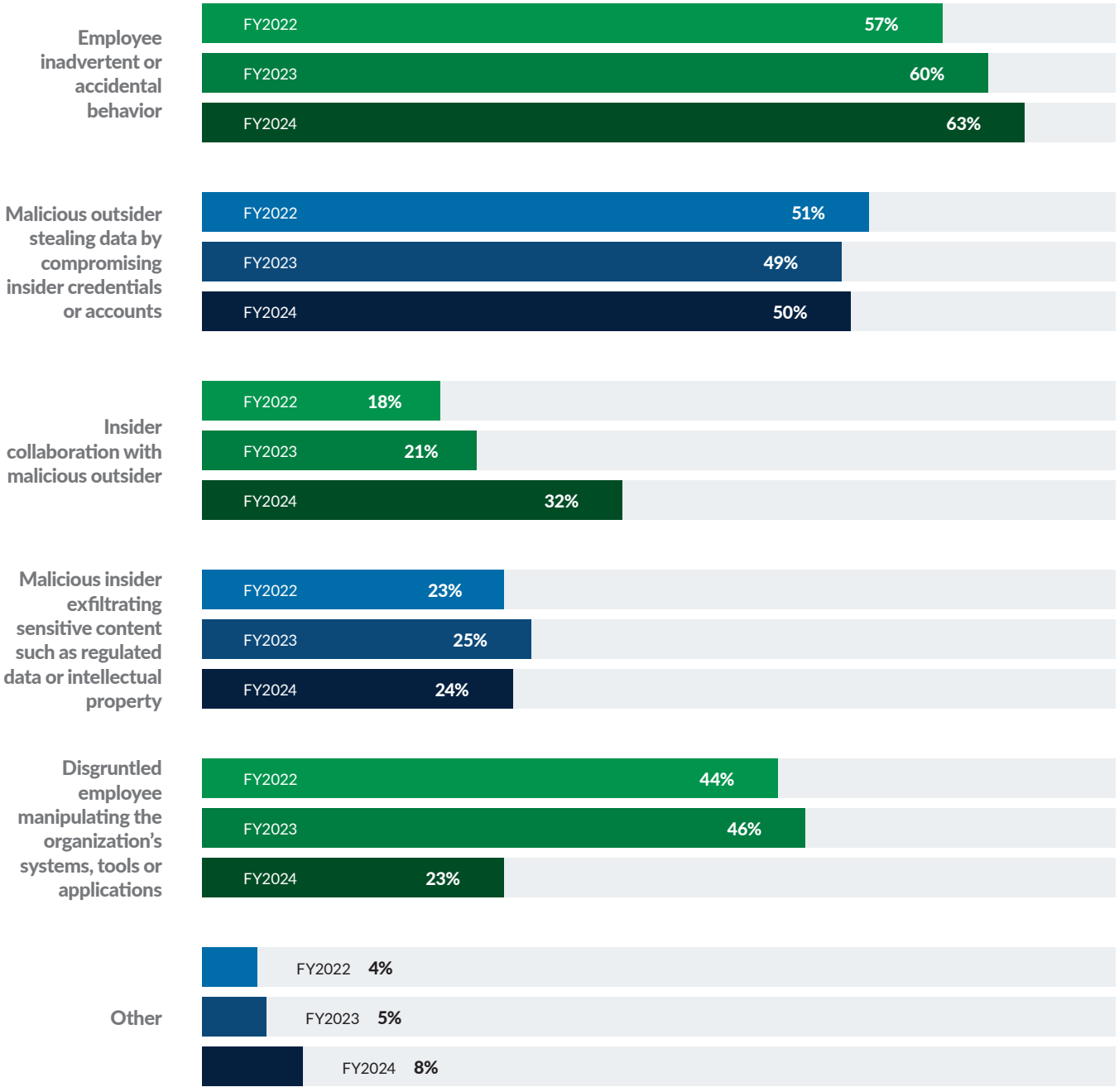
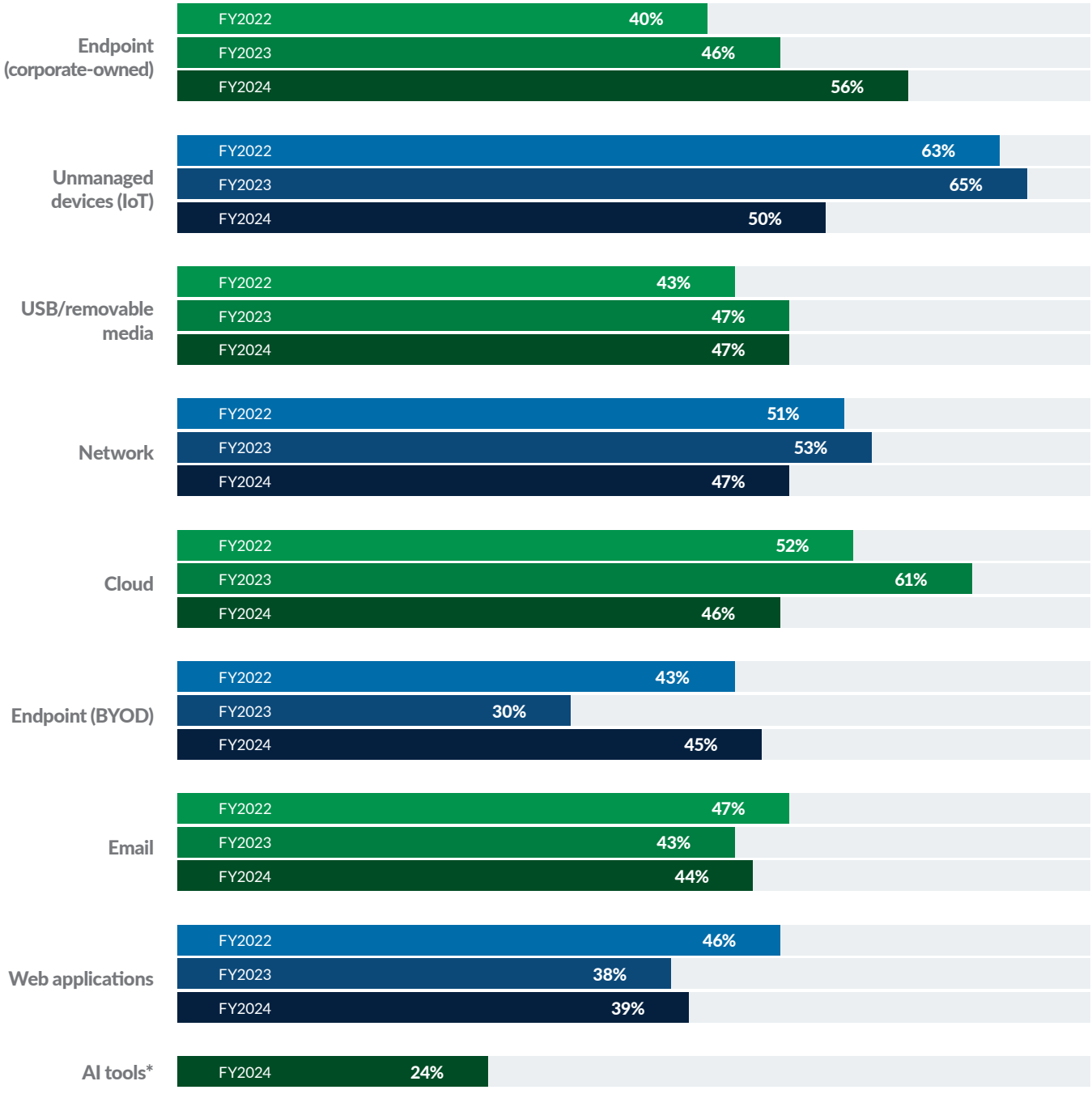


Figure 19

Most concerning channels of insider-driven data loss

Since 2023, endpoints have become the greatest risk to causing insider data loss. As a concern, endpoints have increased significantly from 40% of respondents in 2022 to 56% of respondents in 2024. Fifty percent of respondents say they are worried about unmanaged IoT devices resulting in the loss of sensitive data, a significant decrease from 65% in 2023, as shown in Figure 20. Worries about the cloud as a source of insider-driven data loss has decreased from 61% of respondents in 2023 to 46% of respondents in 2024.



*Not a response in previous years

Figure 20

Where users store their organization's sensitive data

Most sensitive data is on network drives. According to Figure 21, 63% of respondents say network drives have organizations most sensitive data such as personally identifiable information (PII), intellectual property (IP), and other critical business information. The storage of sensitive data on email has declined significantly from 65% of organizations in 2022 to 56% in 2024. Sensitive data stored on databases has increased from 41% of respondents in 2022 to 50% in 2023 and 2024.

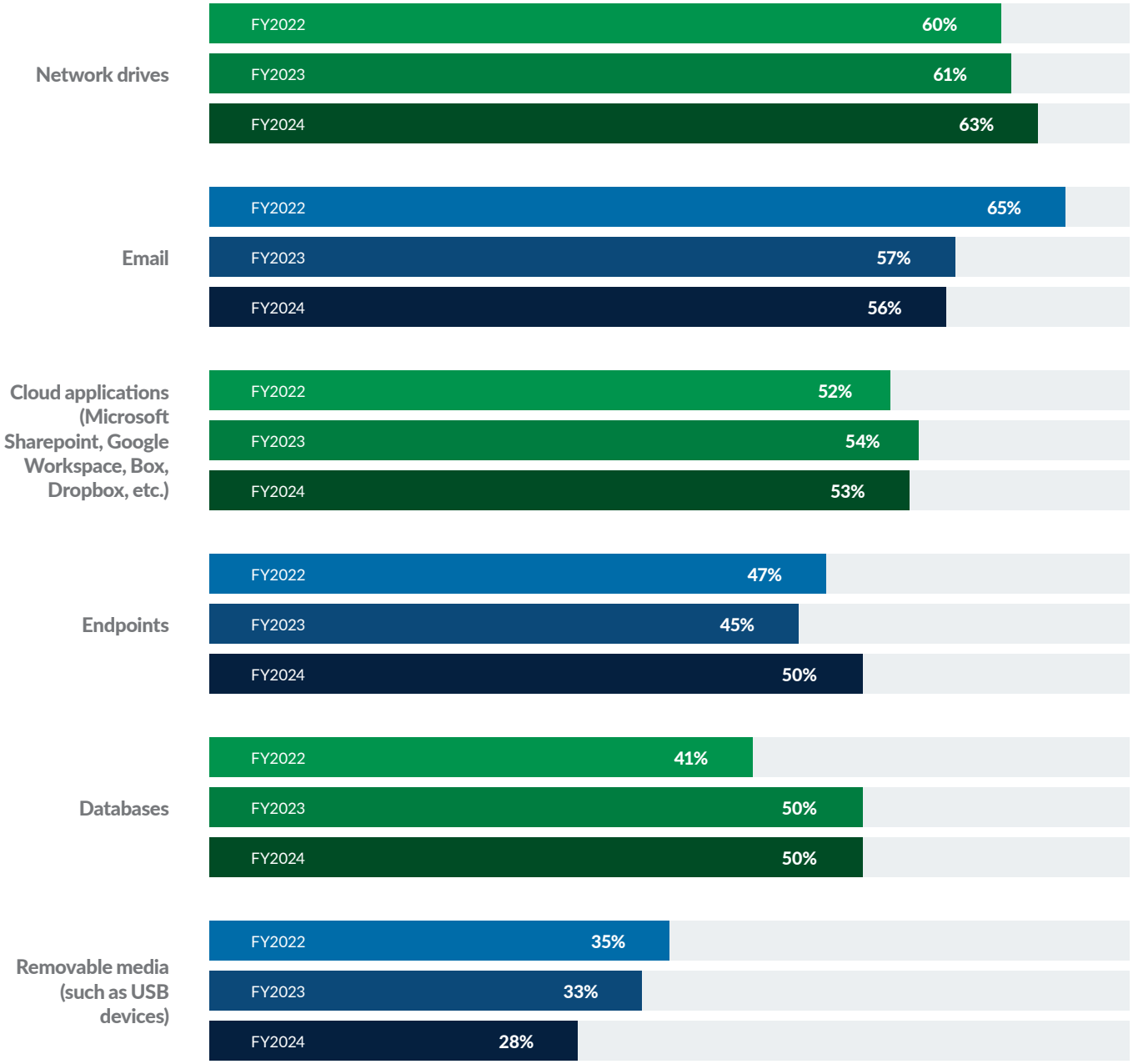


Figure 21

How users communicate and collaborate with colleagues and third parties

As shown in Figure 22, business chat tools and web applications are the top methods used to communicate and collaborate internally (60% of respondents and 52% of respondents, respectively). Corporate email as a communication mechanism has declined from 59% of respondents in 2023 to 49% of respondents in 2024.

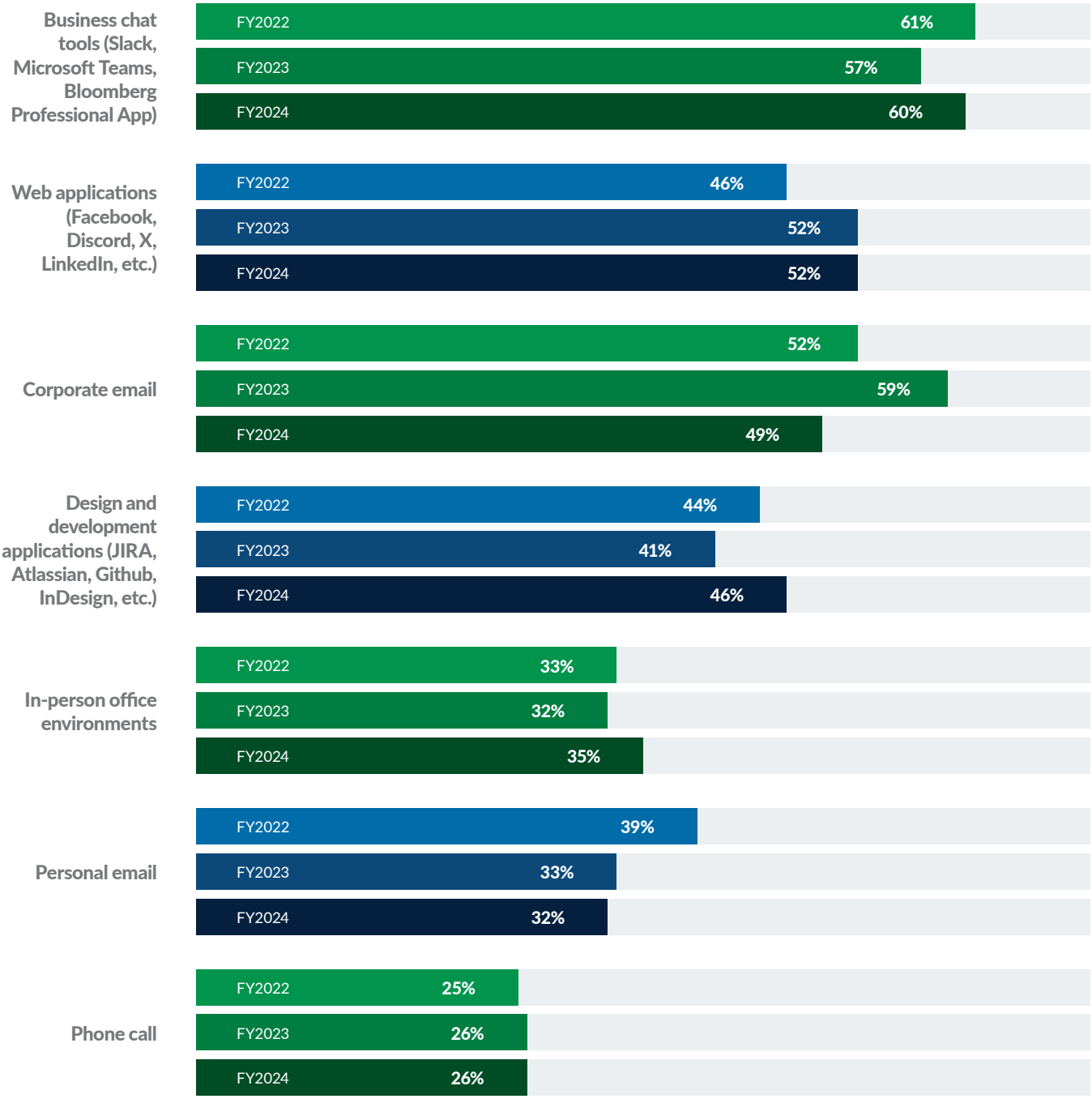


Figure 22

Behaviors of malicious insiders

Malicious insiders use corporate email to steal sensitive data. Figure 23 shows a list of malicious insiders' activities in organizations represented in this research. Sixty-three percent of respondents say malicious insiders emailed sensitive data to outside parties followed by accessing sensitive data not associated with the role or function (63% of respondents).

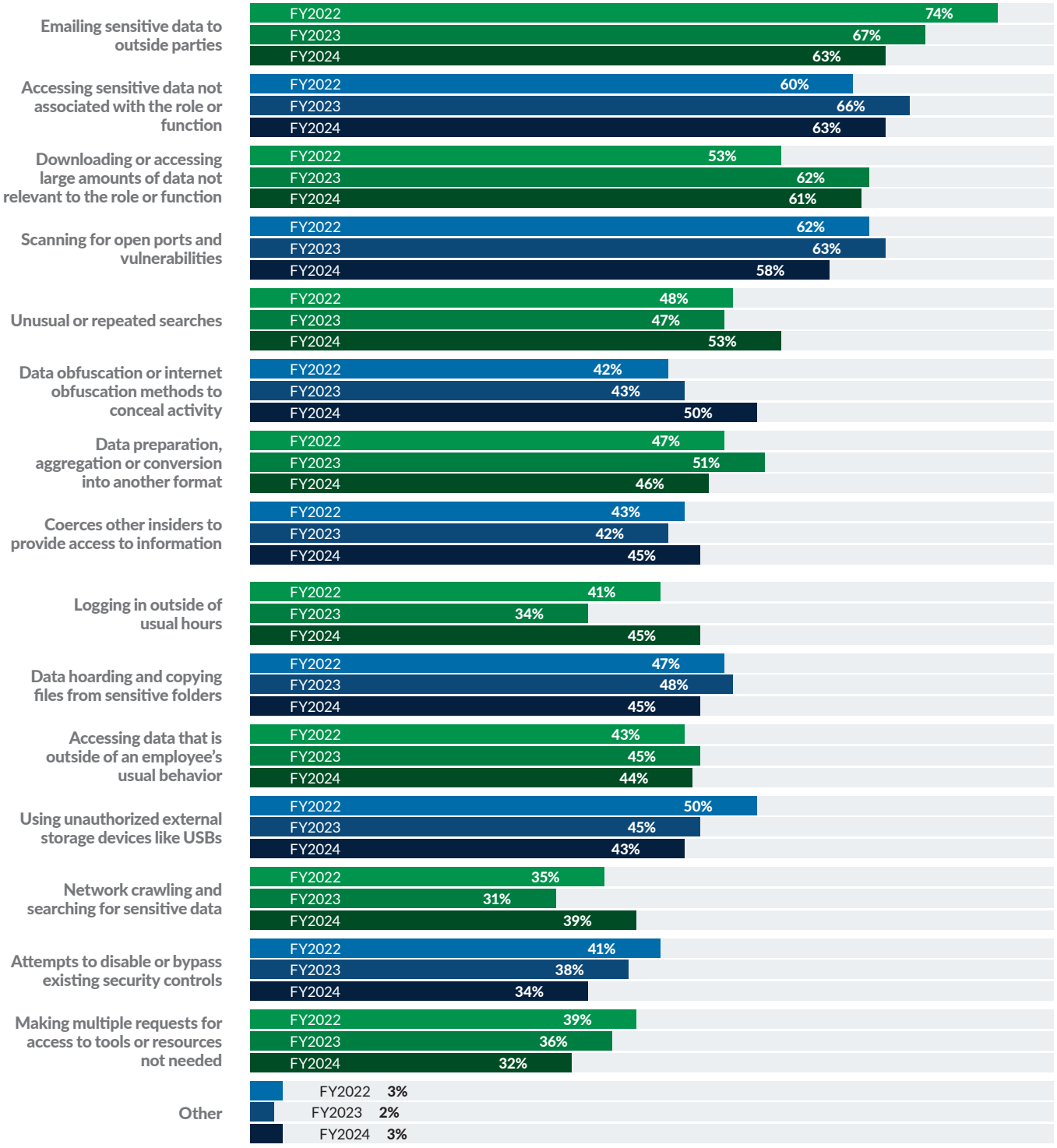
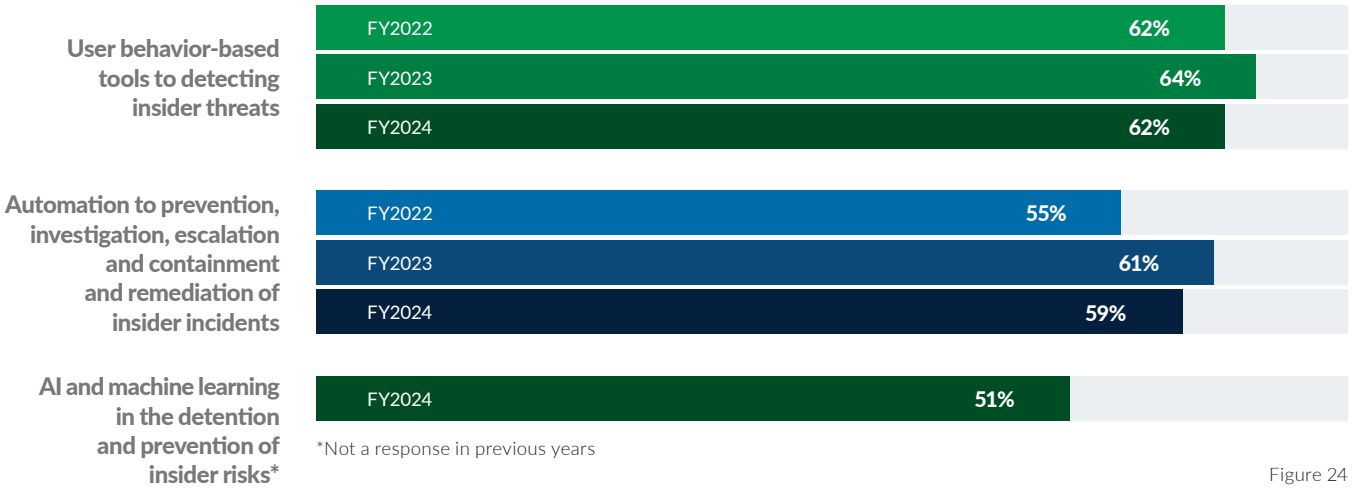


Figure 23

The importance of advanced technologies in reducing insider risks

User behavior-based tools continue to be the most important tool to reducing insider risks. According to Figure 24, 62% of respondents favor user behavior-based tools and 59% of respondents say automation to prevent, investigate, escalate, contain, and remediate insider incidents. For the first time, AI was included, and 51% say it is essential or very important for reducing insider risks.



*Not a response in previous years

Figure 24

Primary business drivers for having an insider risk management program

Industry regulations and standards are the main drivers for having an insider risk management program. Figure 25 presents reasons why organizations represented in this research are making efforts to have an insider risk management program to mitigate insider risks. The regulatory environment is the primary reason (53% of respondents), followed by having a remote/hybrid workforce (46%).

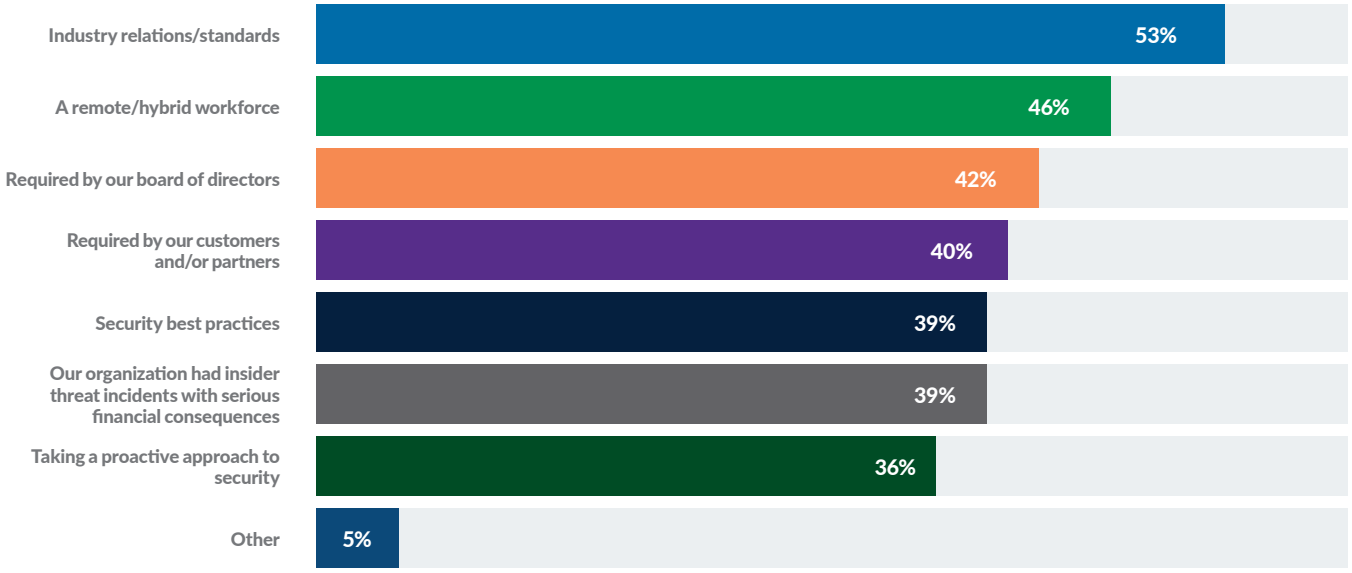


Figure 25

DEMOGRAPHICS

Industry sectors of participating organizations

Figure 26 reports the industry distribution of respondents' organizations. This chart identifies financial services (18%) as the largest industry focus, which includes banking, investment management, insurance, brokerage, payments, and credit cards. This is followed by industrial, retailing, services and technology and software (each at 8% of respondents).

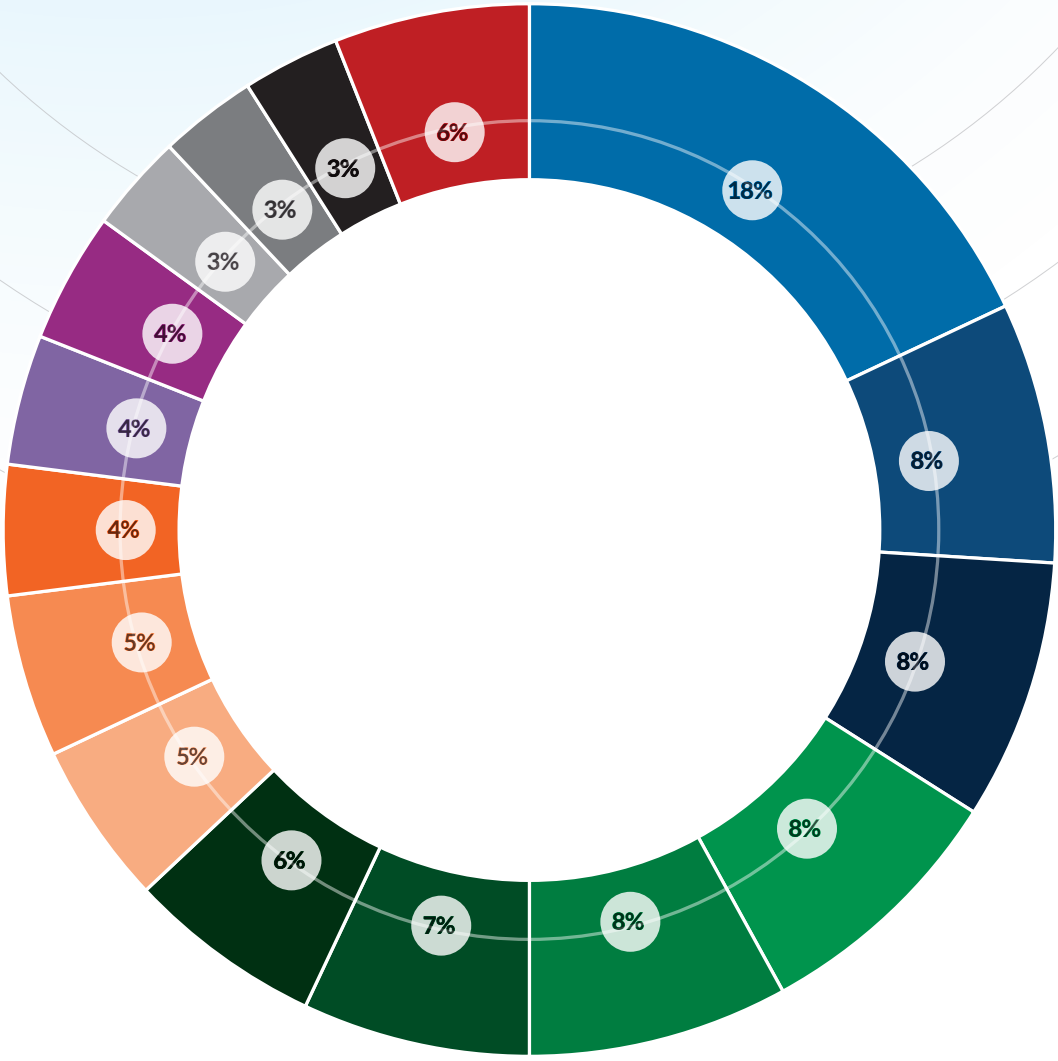


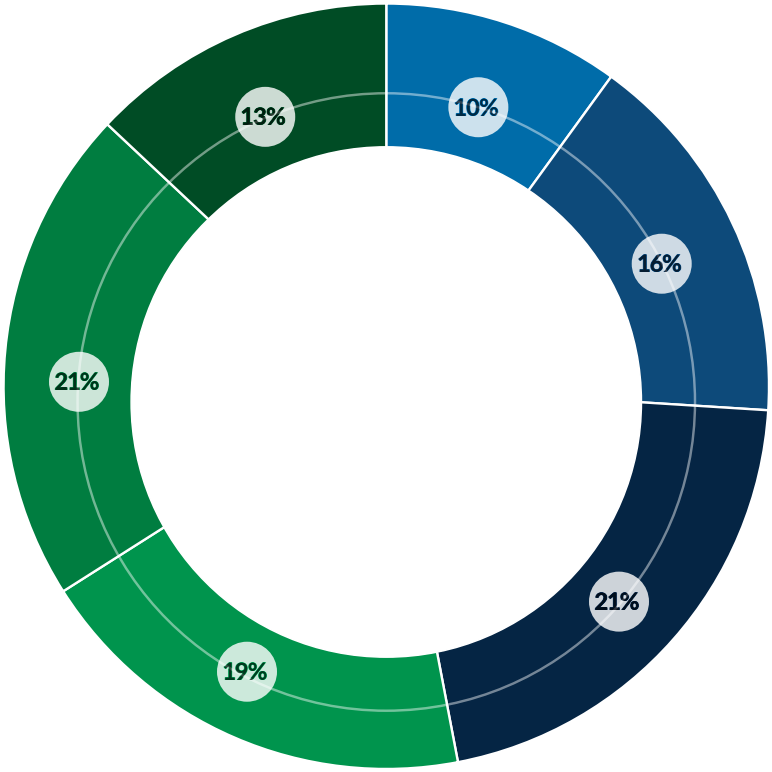
Figure 26

- Financial services
- Industrial
- Retail
- Services
- Technology and software
- Healthcare
- Pharma
- Energy and utilities
- Transportation
- Defense
- Education
- Hospitality
- Communications
- Entertainment and media
- Research
- Other

Headcount (size) for participating organization companies

Figure 27 shows the percentage distribution of companies according to global headcount, which is a surrogate for organizational size. As can be seen, 47% of the sample includes larger-sized companies with more than 5,000 full-time equivalent employees.

Figure 27

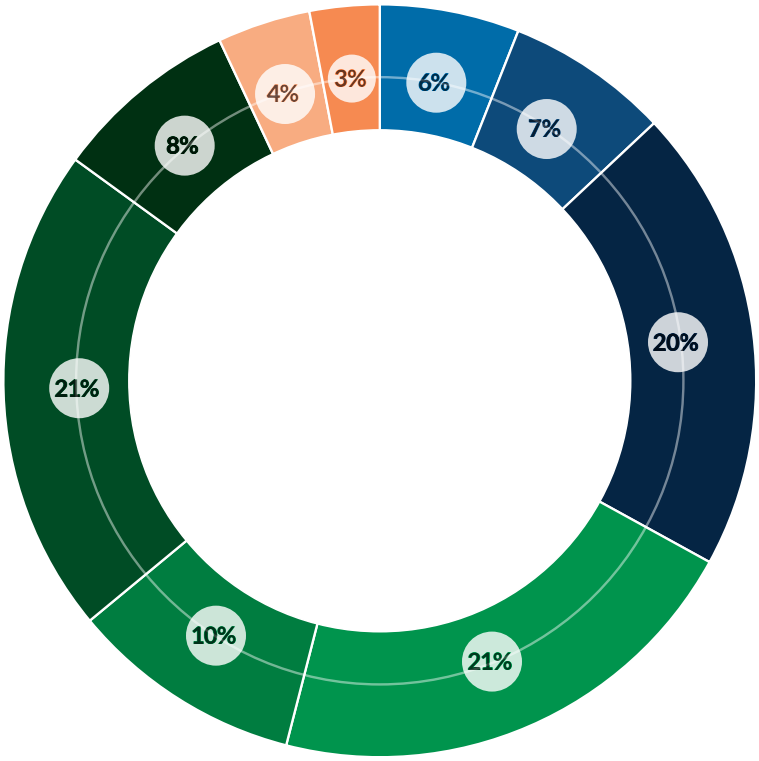


- More than 75,000
- 25,001 to 75,000
- 5,001 to 25,000
- 1,001 to 5,000
- 500 to 1,000
- Less than 500

Respondents by position level or function

Figure 28 reports the respondent's organizational level within participating organizations. Sixty-four percent of respondents are at or above the supervisory levels. The largest categories at 21% of respondents are manager and technician.

Figure 28

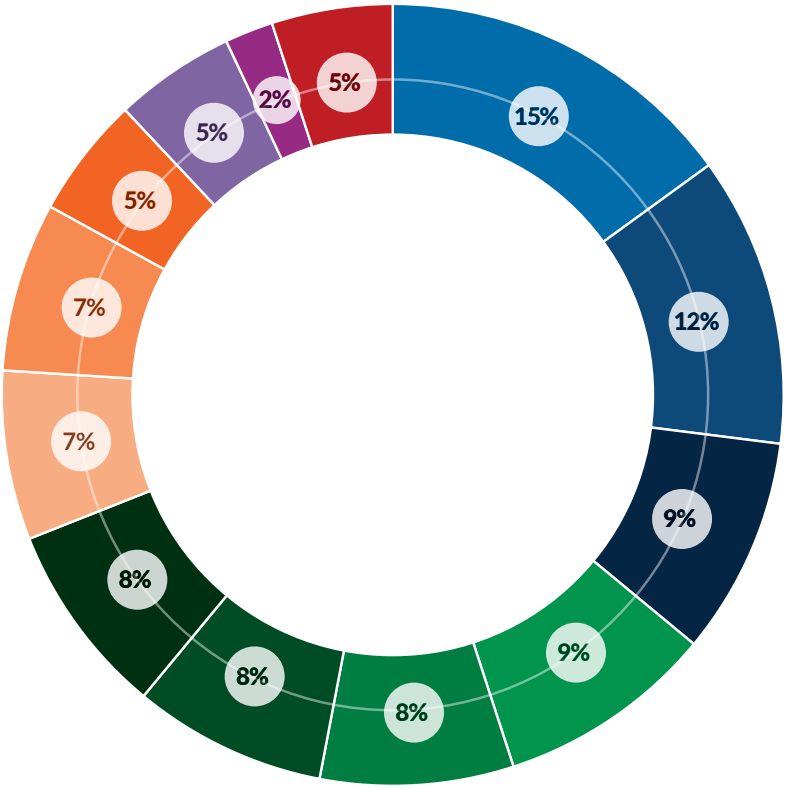


- Senior executive
- Vice president
- Director
- Manager
- Supervisor
- Technician
- Staff
- Contractor
- Other

Direct reporting channel

As shown in Figure 29, 15% of respondents report to the chief information security officer, 12% of respondents report to the chief information officer, 9% of respondents report to the chief financial officer, and 9% of respondents report to the sales or marketing leadership.

Figure 29

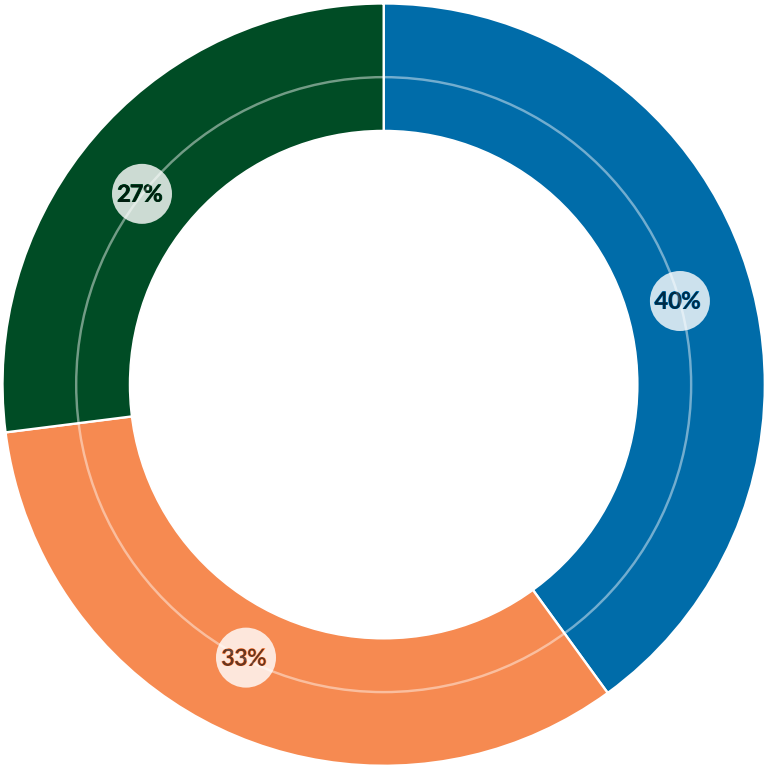


- Chief information security
- Chief information officer
- Chief financial officer
- Sales/marketing leader
- Chief operating officer
- General council
- Human resources VP
- CEO/executive committee
- Compliance officer
- Business or LOB leaders
- Chief security officer
- Chief risk officer
- Other

Regional distribution of global organizations

Figure 30 shows the global regions participating in this research. North America represents the largest segment (40% of companies) and Asia-Pacific is the smallest segment (27% of companies). Because of sample size, we combined Europe and the Middle East to form the EMEA segment (33% of companies).

Figure 30



- North America
- EMEA
- Asia-Pacific

FROM INSIGHTS TO ACTION

Three strategies for maximizing insider risk budgets

As organizations increase investment in insider risk management, the focus must shift to spending those dollars wisely. With post-incident costs rising, the urgency to 'get left of boom' has never been greater. The findings from this report are unequivocal: early risk detection is critical to pre-empting breaches, and safeguarding reputational integrity. Strategic investments in pre-incident measures will be pivotal in driving down the overall cost of insider risk.

To maximize insider risk management investments, organizations must focus on three core strategies:

1 Technology consolidation

Integrating tools like data loss prevention, user behavior analytics, and activity monitoring enables early risk detection. As the findings show (pg. 15), consolidation leads to cost savings, reduced complexity, faster detection, greater scalability, and more actionable data. **Forrester research** further underscores consolidation's financial impact, revealing potential savings of up to $3 million over three years.

2 Empower analysts

Analysts are the first line of defense, and equipping them with AI-driven tools is critical. As per the survey responses (pg. 15), AI accelerates investigations, reduces skill requirements, and amplifies detection capabilities.

3 Leverage headline incidents

Each breach is a call to action. Use these incidents to advocate for additional proactive measures, justifying budget increases and demonstrating the long-term value of continued investment in insider risk management.

As insider risk management budgets expand, focusing on early detection, smarter technology, and strategic monitoring is paramount. Now is the time for decisive, informed action to build a resilient, future-proof security posture.

FRAMEWORK

The purpose of this research is to provide guidance on what an insider risk can cost an organization.

This cost study is unique in addressing the core systems and business process-related activities that drive a range of expenditures associated with a company's response to insider incidents arising from negligence/mistakes, compromise (i.e., credential theft), or malicious/criminal behaviors. In this study, we define an insider-related incident as one that results in the diminishment of a company's core data, networks, or enterprise systems.

Our benchmark methods attempt to elicit the actual experiences and consequences of insider-related incidents. Based on interviews with a variety of senior-level individuals in each organization we classify the costs according to two different cost streams:

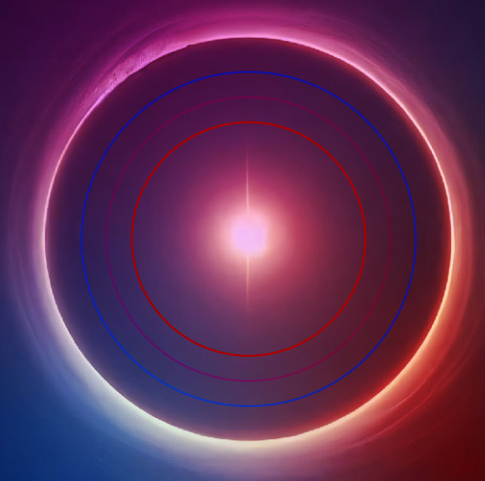
- **The costs related to minimizing insider risks or what we refer to as the internal cost activity centers.**
- **The costs related to the consequences of incidents, or what we refer to as the external effect of the event or attack.**

We analyze the internal cost centers sequentially starting with monitoring and surveillance of the insider risk landscape and ending with remediation activities. Also included are the costs due to lost business opportunities and business disruption. In each of the cost activity centers we asked respondents to estimate the direct costs, indirect costs and, when applicable, opportunity costs.

These are defined as follows:

- **Direct cost:** The direct expense outlay to accomplish a given activity.
- **Indirect cost:** The amount of time, effort and other organizational resources spent, but not as a direct cash outlay.
- **Opportunity cost:** The cost resulting from lost business opportunities as a consequence of reputation diminishment after the incident.

External costs such as the loss of information assets, business disruption, equipment damage, and revenue loss were captured using shadow-costing methods. Total costs were allocated to seven discernible cost vectors[3].



This study addresses the core process-related activities that drive a range of expenditures associated with a company's response to insider-related incidents.

The seven internal cost activity centers in our framework include[4]:

- **Monitoring and surveillance:** Activities that enable an organization to reasonably detect and possibly deter insider incidents or attacks. This includes allocated (overhead) costs of certain enabling technologies that enhance mitigation or early detection.
- **Investigation:** Activities necessary to thoroughly uncover the source, scope, and magnitude of one or more incidents.
- **Escalation:** Activities taken to raise awareness about actual incidents among key stakeholders within the company. The escalation activity also includes the steps taken to organize an initial management response.
- **Incident response:** Activities relating to the formation and engagement of the incident response team including the steps taken to formulate a final management response.
- **Containment:** Activities that focus on stopping or lessening the severity of insider incidents or attacks. These include shutting down vulnerable applications and endpoints.
- **Ex-post analysis:** Activities to help the organization minimize potential future insider-related incidents and attacks. It also includes steps taken to communicate with key stakeholders both within and outside the company, including the preparation of recommendations to minimize potential harm.
- **Remediation:** Activities associated with repairing and remediating the organization's systems and core business processes. These include the restoration of damaged information assets and IT infrastructure.

In addition to these process-related activities, organizations often experience external consequences or costs associated with the aftermath of incidents. Our research shows that four general cost activities associated with these external consequences are as follows:

- **Cost of information loss or theft:** Loss or theft of sensitive and confidential information as a result of an insider attack. Such information includes trade secrets, intellectual properties (including source code), customer information, and employee records. This cost category also includes the cost of data breach notification in the event that personal information is wrongfully acquired.
- **Cost of business disruption:** The economic impact of downtime or unplanned outages that prevent the organization from meeting its data processing requirements.
- **Cost of equipment damage:** The cost to remediate equipment and other IT assets as a result of insider attacks to information resources and critical infrastructure.
- **Lost revenue:** The loss of customers (churn) and other stakeholders because of system delays or shutdowns as a result of an insider attack. To extrapolate this cost, we use a shadow costing method that relies on the 'lifetime value' of an average customer as defined for each participating organization.

3. We acknowledge that these seven cost categories are not mutually independent and they do not represent an exhaustive list of all cost activity centers.
4. Internal costs are extrapolated using labor (time) as a surrogate for direct and indirect costs. This is also used to allocate an overhead component for fixed costs such as multiyear investments in technologies.

BENCHMARKING

Our benchmark instrument is designed to collect descriptive information from IT, information security and other key individuals about the actual costs incurred either directly or indirectly as a result of insider-related incidents or attacks actually detected. Our cost method does not require subjects to provide actual accounting results, but instead relies on estimation and extrapolation from interview data over a four-week period.

Cost estimation is based on confidential diagnostic interviews with key respondents within each benchmarked organization. Data collection methods did not include actual accounting information, but instead relied upon numerical estimation based on the knowledge and experience of each participant. Within each category, cost estimation was a two-stage process. First, the benchmark instrument required individuals to rate direct cost estimates for each cost category by marking a range variable defined in the following number line format.

How to use the number line:

The number line provided under each data breach cost category is one way to obtain your best estimate for the sum of cash outlays, labor and overhead incurred. Please mark only one point somewhere between the lower and upper limits set above. You can reset the lower and upper limits of the number line at any time during the interview process.

Post your estimate of direct costs here for [presented cost category]

LL _____|_____**UL**

The numerical value obtained from the number line rather than a point estimate for each presented cost category preserved confidentiality and ensured a higher response rate. The benchmark instrument also required practitioners to provide a second estimate for indirect and opportunity costs, separately.

Cost estimates were then compiled for each organization based on the relative magnitude of these costs in comparison to a direct cost within a given category. Finally, we administered general interview questions to obtain additional facts, including estimated revenue losses as a result of the insider-related incident or attack.

The size and scope of survey items was limited to known cost categories that cut across different industry sectors. In our experience, a survey focusing on process yields a higher response rate and better quality of results. We also used a paper instrument, rather than an electronic survey, to provide greater assurances of confidentiality.

To maintain complete confidentiality, the survey instrument did not capture company-specific information of any kind. Subject materials contained no tracking codes or other methods that could link responses to participating companies.

We carefully limited items to only those cost activities considered crucial to the measurement of cost to keep the benchmark instrument to a manageable size. Based on discussions with learned experts, the final set of items focused on a finite set of direct or indirect cost activities. After collecting benchmark information, each instrument was examined carefully for consistency and completeness. In this study, a few companies were rejected because of incomplete, inconsistent, or blank responses.

RESEARCH LIMITATIONS

Our study utilizes a confidential and proprietary benchmark method that has been successfully deployed in earlier research.

However, there are inherent limitations with this benchmark research that need to be carefully considered before drawing conclusions from findings.

- **Non-statistical results:** Our study draws upon a representative, non-statistical sample of organizations experiencing one or more insider-related incidents during the past 12 months. Statistical inferences, margins of error, and confidence intervals cannot be applied to these data given that our sampling methods are not scientific.
- **Non-response:** The current findings are based on a small representative sample of benchmarks. In this study, 349 companies completed the benchmark process. Non-response bias was not tested so it is always possible companies that did not participate are substantially different in terms of underlying data breach cost.
- **Sampling-frame bias:** Because our sampling frame is judgmental, the quality of results is influenced by the degree to which the frame is representative of the population of companies being studied. It is our belief that the current sampling frame is biased toward companies with more mature privacy or information security programs.
- **Company-specific information:** The benchmark information is sensitive and confidential. Thus, the current instrument does not capture company-identifying information. It also allows individuals to use categorical response variables to disclose demographic information about the company and industry category.
- **Unmeasured factors:** To keep the interview script concise and focused, we decided to omit other important variables from our analyses such as leading trends and organizational characteristics. The extent to which omitted variables might explain benchmark results cannot be determined.
- **Extrapolated cost results:** The quality of benchmark research is based on the integrity of confidential responses provided by respondents in participating companies. While certain checks and balances can be incorporated into the benchmark process, there is always the possibility that respondents did not provide accurate or truthful responses. In addition, the use of cost extrapolation methods rather than actual cost data may inadvertently introduce bias and inaccuracies.

Advancing Responsible Information Management

Ponemon Institute is dedicated to independent research and education that advances responsible information and privacy management practices within business and government. Our mission is to conduct high quality, empirical studies on critical issues affecting the management and security of sensitive information about people and organizations.

We uphold strict data confidentiality, privacy, and ethical research standards. We do not collect any personally identifiable information from individuals (or company identifiable information in our business research). Furthermore, we have strict quality standards to ensure that subjects are not asked extraneous, irrelevant, or improper questions.

The Trusted Leader for Insider Risk Management

As the trusted leader of insider risk management, DTEX transforms enterprise security by displacing reactive tools with a proactive solution that stops insider risks from becoming data breaches. DTEX InTERCEPT™ consolidates data loss prevention, user activity monitoring, and user behavior analytics in one lightweight platform to enable organizations to achieve a trusted and protected workforce. Backed by behavioral science, powered by AI, and used by governments and organizations around the world, DTEX is the trusted authority for protecting data and people at scale with privacy by design.

DTEX and InTERCEPT are trademarks of DTEX Systems Inc. in the United States and other countries. All other trademarks contained herein are property of their respective owners.


To learn more about DTEX,
visit dtexsystems.com.
DTEX